UTH UNIVERSITY OF TRANSPORT HOCHIMINH CITY

TRƯỜNG ĐẠI HỌC GIAO THÔNG VẬN TẢI
THÀNH PHỐ HỒ CHÍ MINH
BAN CÔNG NGHỆ SỐ

ĐIỆN TOÁN ĐÁM MÂY

Chương 4 – An toàn, bảo mật và quản trị

Điện toán đám mây

Số tín chỉ: **3**

Giảng viên: TS. Lê Quốc Tuấn
Email : Tuan.le@ut.edu.vn

Dẫn nhập

Tình huống: lộ dữ liệu trên cloud

- Một nhóm triển khai ứng dụng Web lên cloud trong thời gian ngắn.
- Bucket lưu trữ log và file khách hàng bị cấu hình công khai.
- Tài khoản quản trị dùng mật khẩu yếu, không bật xác thực đa yếu tố.
- Không có nhật ký kiểm toán nên khó xác định ai đã truy cập dữ liệu.

Câu hỏi: lỗi nằm ở công nghệ cloud hay quy trình quản trị của người dùng?

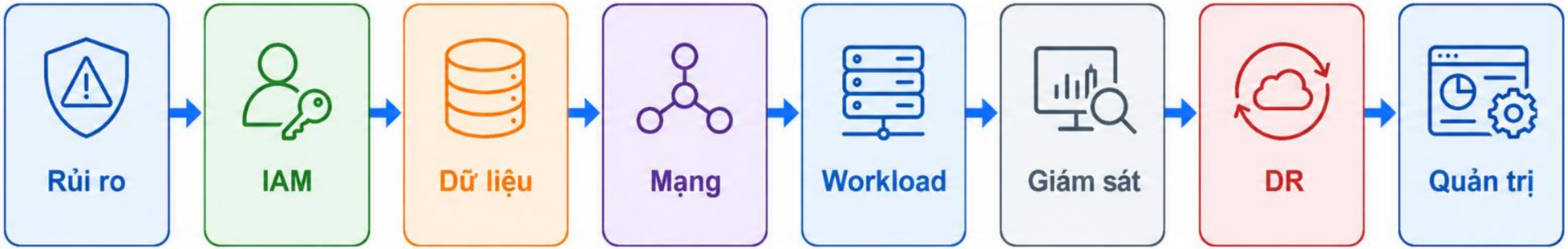


Mục tiêu học tập

- Phân tích được rủi ro và mối đe dọa trong môi trường đám mây.
- Giải thích mô hình chia sẻ trách nhiệm giữa khách hàng và nhà cung cấp.
- Cấu hình được nguyên tắc danh tính, phân quyền, bảo vệ mạng và dữ liệu.
- Mô tả được giám sát, ghi log, ứng phó sự cố và phục hồi thảm họa.
- Đề xuất được kiến trúc cloud an toàn ở mức cơ bản cho doanh nghiệp.



Bản đồ nội dung chương 4



1. Tổng quan rủi ro và mô hình trách nhiệm



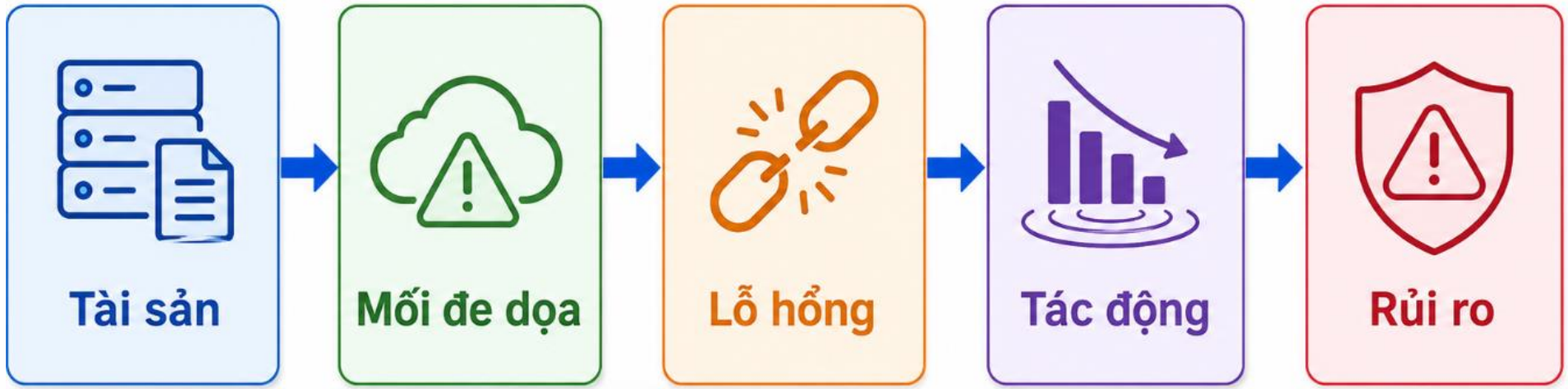
Bảo mật đám mây và hợp tác trong không gian

Bảo mật cloud là gì?

- **Bảo mật Cloud (Cloud Security)** hay An ninh mạng đám mây là tập hợp các chính sách, công nghệ, quy trình và kiểm soát được triển khai để bảo vệ dữ liệu, ứng dụng, dữ liệu danh tính và hạ tầng điện toán đám mây khỏi các mối đe dọa an ninh mạng, truy cập trái phép và tổn thất dữ liệu.
- Điểm khác biệt cốt lõi của bảo mật Cloud so với bảo mật hạ tầng truyền thống (On-Premises) là: **Sự chuyển dịch từ bảo vệ "Chu vi mạng" (Network Perimeter - tường lửa vật lý) sang bảo vệ "Dữ liệu & Danh tính" (Data & Identity)** trong một môi trường phân tán.



Tài sản, mối đe dọa, lỗ hổng và rủi ro



- Rủi ro phát sinh khi mối đe dọa khai thác lỗ hổng và gây tác động đến tài sản?
- Tài sản: dữ liệu, hệ thống, tài khoản, khóa, ứng dụng, cấu hình.
- Mối đe dọa: tác nhân hoặc sự kiện có khả năng gây hại.
- Lỗ hổng: điểm yếu kỹ thuật, quy trình hoặc con người.
- Rủi ro = khả năng xảy ra × mức độ tác động.

Mô hình Trách nhiệm Dùng chung (Shared Responsibility Model)

- Đây là **nguyên tắc nền tảng nhất** trong bảo mật Cloud. An ninh không hoàn toàn thuộc về nhà cung cấp dịch vụ Cloud (Cloud Provider như AWS, GCP, Azure), cũng không hoàn toàn thuộc về khách hàng. Ranh giới trách nhiệm phụ thuộc vào mô hình dịch vụ.
- **Quy tắc vàng:** Nhà cung cấp Cloud chịu trách nhiệm **Bảo mật CHO Đám mây** (Security *OF* the Cloud - hạ tầng vật lý, trung tâm dữ liệu), còn bạn chịu trách nhiệm **Bảo mật TRONG Đám mây** (Security *IN* the Cloud - dữ liệu, mã nguồn, phân quyền).

Mô hình chia sẻ trách nhiệm



Trách nhiệm thay đổi theo mô hình dịch vụ

Thành phần	IaaS	PaaS	SaaS
Hệ điều hành	Khách hàng	Nhà cung cấp	Nhà cung cấp
Ứng dụng	Khách hàng	Khách hàng	Nhà cung cấp
Dữ liệu	Khách hàng	Khách hàng	Khách hàng
Danh tính & quyền	Khách hàng	Khách hàng	Khách hàng
Hạ tầng vật lý	Nhà cung cấp	Nhà cung cấp	Nhà cung cấp

Bề mặt tấn công trong cloud

- **Bề mặt tấn công trong Cloud (Cloud Attack Surface)** là tổng thể tất cả các điểm mút (endpoints), giao diện (interfaces), điểm truy cập, đường truyền mạng, tài nguyên cấu hình và mã nguồn mà kẻ tấn công (attacker) có thể khai thác để xâm nhập, đánh cắp dữ liệu hoặc phá hoại hệ thống đám mây của doanh nghiệp.
- Khác với hạ tầng On-Premises có chu vi mạng rõ ràng (vật lý, Data Center), môi trường Cloud có đặc tính **động (dynamic), phân tán (distributed), và mở rộng liên tục**, khiến bề mặt tấn công rộng hơn, phức tạp hơn và thay đổi theo từng giây.

Bề mặt tấn công trong cloud

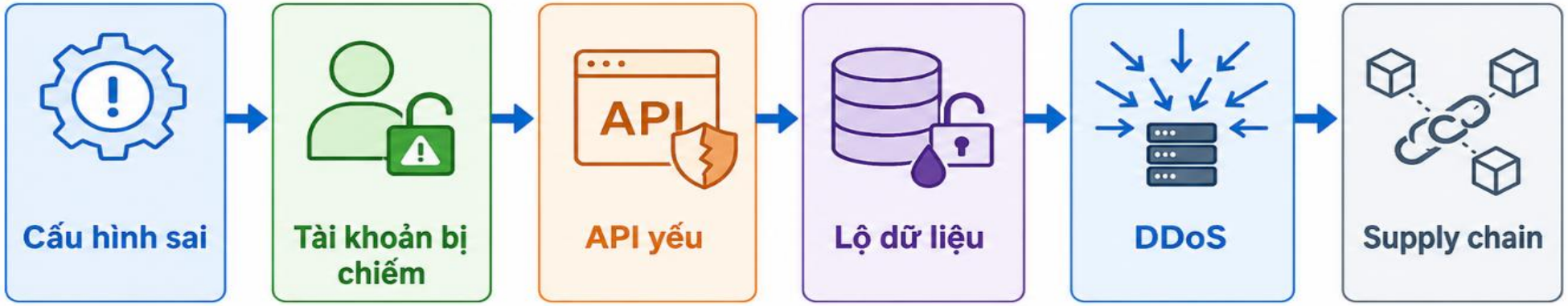
- Tài khoản quản trị và khóa truy cập.
- API quản trị, giao diện console, CLI và SDK.
- Máy ảo, container, serverless function, database.
- Mạng công khai, load balancer, WAF, endpoint và VPN.
- Bucket lưu trữ, snapshot, backup và log.
- Pipeline CI/CD, registry, mã nguồn và secret.



Các rủi ro phổ biến trong môi trường cloud

- Môi trường điện toán đám mây (Cloud Computing) mang lại sự linh hoạt và khả năng mở rộng tuyệt vời, nhưng đồng thời cũng giới thiệu những mặt trận rủi ro hoàn toàn mới so với hạ tầng truyền thống.
- **Các rủi ro phổ biến và nghiêm trọng nhất** trong môi trường Cloud, được tổng hợp dựa trên các báo cáo uy tín hàng đầu về An ninh mạng (như *OWASP Top 10 Cloud Security Risks* và *CSA Top Threats*).

Các rủi ro phổ biến trong môi trường cloud



- Cấu hình công khai sai đối với bucket, database, firewall hoặc dashboard.
- Khóa truy cập bị đưa lên GitHub hoặc lưu trong máy cá nhân.
- Ứng dụng thiếu kiểm soát truy cập ở API.
- Không có giám sát nên phát hiện sự cố chậm.

Cấu hình sai: lỗi nhỏ, hậu quả lớn

- Bucket lưu trữ hoặc database cho phép truy cập công khai.
- Security group mở cổng quản trị từ Internet.
- Role cấp quyền quá rộng: wildcard, quyền quản trị toàn tài khoản.
- Không bật mã hóa, logging hoặc versioning cho dữ liệu quan trọng.



Chiếm đoạt tài khoản cloud

- Tấn công phishing đánh cắp mật khẩu hoặc mã đăng nhập.
- Rò rỉ access key trong mã nguồn, log, file cấu hình hoặc máy cá nhân.
- Tài khoản không bật MFA hoặc có quyền quá cao.
- Kẻ tấn công dùng tài khoản hợp lệ nên khó phát hiện hơn tấn công mạng thông thường.



API không an toàn

- Cloud và ứng dụng hiện đại được điều khiển mạnh qua API.
- API yếu có thể gây lộ dữ liệu, thay đổi cấu hình hoặc leo thang đặc quyền.
- Các lỗi thường gặp: thiếu xác thực, phân quyền sai, rate limit yếu, validate đầu vào kém.
- Cần kết hợp IAM, API gateway, logging, WAF và kiểm thử bảo mật.



Rủi ro chuỗi cung ứng phần mềm

- Mã nguồn, thư viện, container image và pipeline CI/CD đều có thể bị tấn công.
- Ảnh container chứa lỗ hổng hoặc secret hard-code.
- Registry hoặc pipeline bị chiếm có thể phát tán phiên bản độc hại.
- Cần kiểm tra nguồn gốc, ký số, quét lỗ hổng và kiểm soát quyền pipeline.

Ma trận đánh giá rủi ro cloud

Khả năng / Tác động	Thấp	Trung bình	Cao
Cao	Ưu tiên 3	Ưu tiên 2	Ưu tiên 1
Trung bình	Theo dõi	Ưu tiên 3	Ưu tiên 2
Thấp	Chấp nhận	Theo dõi	Ưu tiên 3

- Ưu tiên xử lý rủi ro có khả năng xảy ra cao và tác động lớn.
- Đánh giá rủi ro phải cập nhật khi thêm dịch vụ, mở quyền hoặc thay đổi kiến trúc.

Bảng Chiến lược Giảm thiểu Rủi ro

Nhóm rủi ro	Giải pháp & Công cụ phòng ngừa cốt lõi
Bảo mật Cấu hình	Triển khai công cụ **CSPM** (Cloud Security Posture Management) để tự động quét & sửa lỗi cấu hình.
Bảo mật Danh tính	Áp dụng nguyên tắc **Least Privilege**, bắt buộc **MFA**, triển khai **IMDSv2** chống SSRF.
Chi phí	Thiết lập **Budget Alerts** (cảnh báo hạn mức ngân sách), áp dụng thực hành **FinOps**.
Vận hành & Mã nguồn	Sử dụng **Infrastructure as Code (IaC)** (Terraform), triển khai quy trình **DevSecOps** kiểm tra mã nguồn từ khâu CI/CD.

2. Quản lý danh tính và truy cập

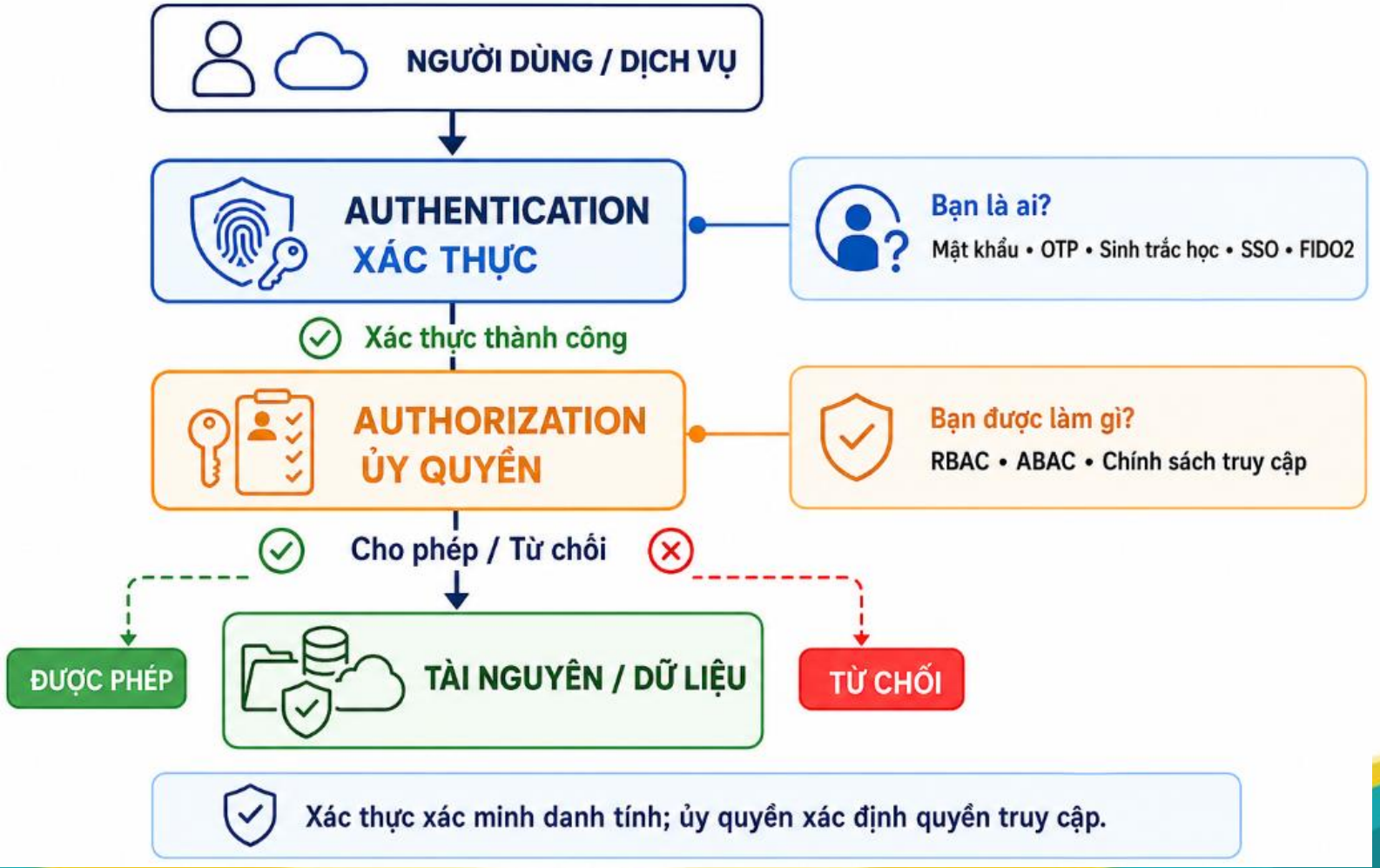
- **Quản lý Danh tính và Truy cập (Identity and Access Management - IAM)** là trung tâm của mọi hạ tầng an ninh mạng hiện đại. Khi ranh giới mạng truyền thống (tường lửa vật lý) dần xóa bỏ do sự bùng nổ của Cloud và làm việc từ xa, **Danh tính (Identity) đã trở thành chu vi bảo mật mới (The New Security Perimeter).**
- IAM đảm bảo đúng đối tượng (máy tính, con người, dịch vụ) truy cập đúng tài nguyên, đúng thời điểm,



IAM là gì?

- Identity and Access Management quản lý ai được phép làm gì trên tài nguyên nào.
- Bao gồm người dùng, nhóm, vai trò, chính sách, khóa truy cập và nhật ký hoạt động.
- IAM áp dụng cho cả người, ứng dụng, máy ảo, container và dịch vụ tự động.
- IAM tốt giúp giảm rủi ro chiếm quyền và giới hạn hậu quả khi bị lộ tài khoản.

Xác thực và ủy quyền



Xác thực và ủy quyền

- Authentication (AuthN - Xác thực): Quy trình kiểm tra và xác minh danh tính của người dùng hoặc hệ thống.
  - ✓Phương thức: Mật khẩu, Mã OTP, Sinh trắc học (Vân tay, Face ID), Khóa FIDO2/Passkeys.
- Authorization (AuthZ - Ủy quyền): Quy trình xác định xem danh tính đã xác thực có quyền thực hiện hành vi cụ thể trên tài nguyên hay không.
  - ✓Phương thức: Bảng phân quyền, Chính sách (Policies), Vai trò (Roles).

Các loại danh tính trong cloud

Quản lý Danh tính Phi con người (Non-Human Identity Management)

- Trong kỷ nguyên Microservices và Cloud, số lượng **Service Accounts, API Keys, Tokens, SSH Keys, Certificates** thường nhiều gấp 10-50 lần số lượng tài khoản con người.
- **Rủi ro:** Hardcode secret trong mã nguồn, lộ API key trên GitHub.
- **Giải pháp:** Sử dụng các công cụ Secrets Management chuyên dụng (như HashiCorp Vault, AWS Secrets Manager) kết hợp xoay vòng khóa tự động.

Xác thực đa yếu tố

- Kết hợp ít nhất hai nhóm yếu tố: biết, sở hữu, sinh trắc học.
- Giảm rủi ro khi mật khẩu bị lộ qua phishing hoặc reuse.
- Nên bắt buộc MFA cho tài khoản quản trị và tài khoản có quyền nhạy cảm.
- Ưu tiên phương thức chống phishing cho tài khoản đặc quyền.

Các Mô hình Kiểm soát Truy cập (Access Control Models)

Để thực thi khâu Ủy quyền (Authorization), các hệ thống áp dụng các mô hình kiểm soát truy cập chính:

- **RBAC (Role-Based Access Control):** Gán quyền hạn dựa trên **Vai trò** (Role) của người dùng trong tổ chức.
  - *Ví dụ:* Vai trò Developer được đọc/ghi code, vai trò Auditor chỉ được xem log.
- **ABAC (Attribute-Based Access Control):** Gán quyền linh hoạt dựa trên **Thuộc tính** (Attributes) của đối tượng, tài nguyên, và ngữ cảnh môi trường.
  - *Ví dụ:* Cho phép HR Admin xem Hồ sơ nhân viên ĐIỀU KIỆN LÀ Từ IP nội bộ VÀ Trong giờ hành chính.
- **PBAC / CBAC (Policy/Context-Based Access Control):** Kiểm soát truy cập dựa trên chính sách động, liên tục đánh giá mức độ rủi ro của thiết bị và vị trí thực tế thời gian thực.

Kiến trúc & Công nghệ IAM Tiên tiến

- **SSO (Single Sign-On) & Federated Identity**
- **SSO:** Cho phép người dùng đăng nhập **một lần duy nhất** để truy cập vào hàng chục ứng dụng khác nhau mà không cần gõ lại mật khẩu.
- **Liên kết danh tính (Federation):** Cho phép sử dụng danh tính từ một nhà cung cấp (Identity Provider - IdP như Microsoft Entra ID, Okta, Google Workspace) để truy cập ứng dụng của bên thứ ba.
- **Giao thức cốt lõi:**
  - **OAuth 2.0:** Giao thức **Ủy quyền** (Authorization) phổ biến cho Web/Mobile API.
  - **OIDC (OpenID Connect):** Lớp **Xác thực** (Authentication) nằm trên OAuth 2.0.
  - **SAML 2.0:** Giao thức trao đổi danh tính chuẩn doanh nghiệp (Enterprise Federation).

Kiến trúc & Công nghệ IAM Tiên tiến

PAM (Privileged Access Management)

- Quản lý các tài khoản có **đặc quyền cao nhất** (Root, Domain Admin, Cloud Superuser) - mục tiêu hàng đầu của hacker.
- Tự động xoay vòng mật khẩu (Password Rotation).
- Cấp quyền vừa đủ và đúng lúc (**Just-In-Time Access**).
- Ghi hình và giám sát toàn bộ phiên làm việc của tài khoản đặc quyền (Session Recording).

Nguyên lý IAM trong Kiến trúc Zero Trust

- IAM là **trái tim** của mô hình an ninh mạng **Zero Trust (Never Trust, Always Verify)**:
- **Explicit Verification (Xác minh rõ ràng):** Luôn xác thực và ủy quyền dựa trên mọi dữ liệu khả dụng (danh tính, vị trí, thiết bị, dịch vụ, dữ liệu).
- **Least Privilege Access (Quyền tối thiểu):** Giới hạn quyền truy cập bằng Just-In-Time (JIT) và Just-Enough-Access (JEA) kết hợp chính sách dựa trên rủi ro.
- **Assume Breach (Giả định hệ thống đã bị xâm nhập):** Thu hẹp vùng ảnh hưởng (Blast Radius) bằng cách phân đoạn truy cập chặt chẽ theo danh tính.

Nguyên tắc đặc quyền tối thiểu

- Chỉ cấp quyền cần thiết, trong phạm vi cần thiết, trong thời gian cần thiết.
- Tránh quyền quản trị toàn cục cho công việc hằng ngày.
- Ưu tiên quyền tạm thời thay vì access key dài hạn.
- Rà soát quyền định kỳ và loại bỏ quyền không còn sử dụng.

Tài khoản dịch vụ và quyền tạm thời

- Ứng dụng, máy ảo, container và serverless nên dùng service identity riêng.
- Không hard-code access key trong mã nguồn hoặc file cấu hình.
- Dùng role/managed identity để cấp quyền tạm thời cho workload.
- Phân tách quyền đọc, ghi, quản trị và triển khai.

Quản lý tài khoản đặc quyền

- Tài khoản root/owner chỉ dùng cho tình huống đặc biệt.
- Tách tài khoản quản trị khỏi tài khoản sử dụng hằng ngày.
- Bật MFA, cảnh báo đăng nhập và ghi log mọi thao tác đặc quyền.
- Áp dụng phê duyệt hoặc cấp quyền tạm thời cho thao tác nhạy cảm.

Các lỗi IAM thường gặp

- Dùng chung tài khoản giữa nhiều người.
- Không bật MFA cho tài khoản quản trị.
- Cấp quyền wildcard quá rộng.
- Access key không xoay vòng hoặc không biết đang dùng ở đâu.
- Không xóa tài khoản cũ của nhân sự đã nghỉ.
- Không bật log kiểm toán hoạt động IAM.

Tổng kết Các Dịch vụ IAM trên Cloud

Tính năng	AWS	Google Cloud (GCP)	Microsoft Azure / Entra ID
Quản lý Danh tính Gốc	AWS IAM / Identity Center	Cloud IAM	Microsoft Entra ID (Azure AD)
Identity Federation	OIDC / SAML 2.0	Google Workspace / OIDC	Entra B2B / B2C
Quản lý Secrets/Keys	AWS Secrets Manager / KMS	Secret Manager / KMS	Azure Key Vault
Chính sách phân quyền	JSON Policies (Resource & Identity)	IAM Roles (Primitive, Predefined, Custom)	RBAC & Conditional Access

3. Bảo vệ dữ liệu cloud

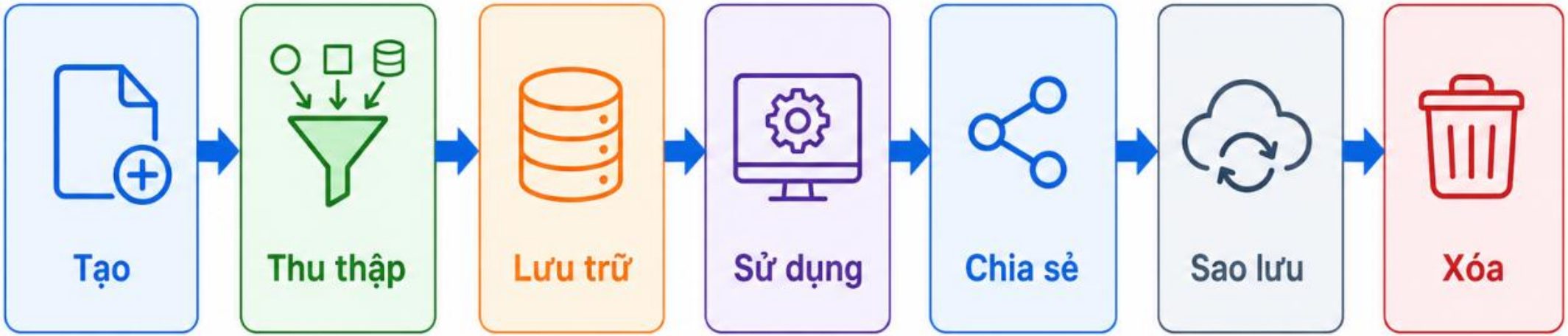
- Dữ liệu là tài sản trọng yếu; bảo vệ dữ liệu cần bắt đầu từ phân loại, mã hóa và kiểm soát vòng đời.



Phân loại dữ liệu

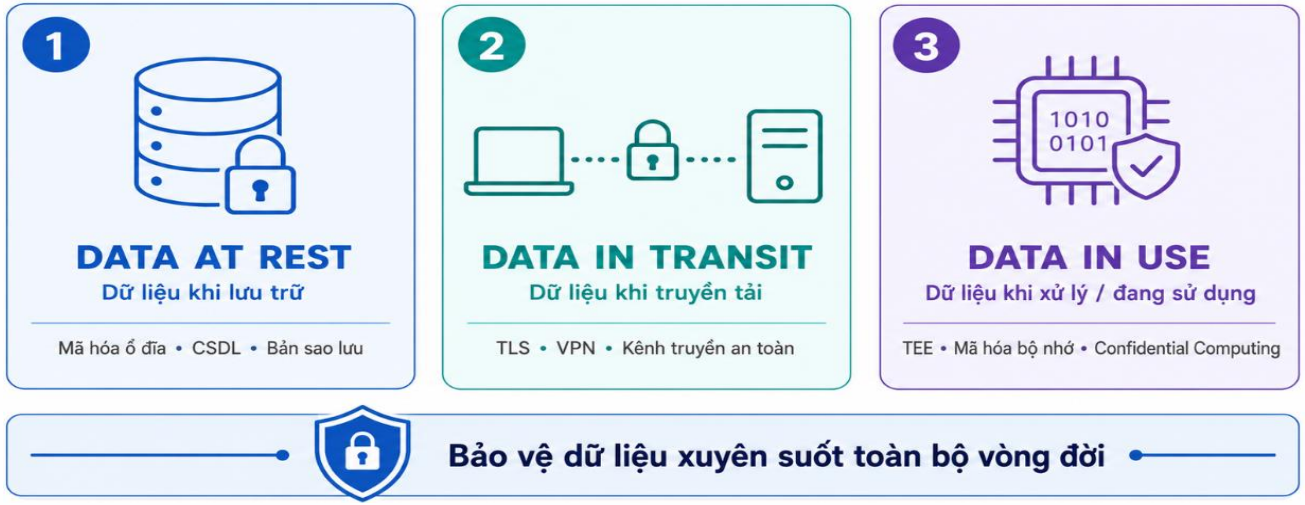
- Công khai: tài liệu quảng bá, dữ liệu được phép chia sẻ.
- Nội bộ: tài liệu vận hành, cấu hình hệ thống, báo cáo nội bộ.
- Nhạy cảm: thông tin cá nhân, tài chính, hợp đồng, dữ liệu khách hàng.
- Bí mật: khóa mã hóa, secret, tài liệu chiến lược, dữ liệu có yêu cầu pháp lý cao.

Vòng đời dữ liệu trên cloud



- Mỗi giai đoạn cần kiểm soát quyền, mã hóa, log và chính sách lưu giữ.
- Dữ liệu sao lưu, snapshot và log cũng cần được bảo vệ như dữ liệu gốc.
- Xóa dữ liệu phải có quy trình, không chỉ xóa giao diện ứng dụng.

Ba trạng thái dữ liệu cần mã hóa



- Mã hóa khi lưu trữ bảo vệ dữ liệu trên đĩa, object storage, backup.
- Mã hóa khi truyền bảo vệ dữ liệu qua mạng.
- Mã hóa khi xử lý là hướng nâng cao cho dữ liệu nhạy cảm trong môi trường thực thi.

Mã hóa dữ liệu khi truyền

- Sử dụng HTTPS/TLS cho Web, API và kết nối dịch vụ.
- Dùng VPN hoặc kết nối riêng cho kênh giữa doanh nghiệp và cloud.
- Không truyền mật khẩu, token hoặc secret qua kênh không mã hóa.
- Kiểm tra chứng chỉ, phiên bản giao thức và cấu hình cipher phù hợp.

Mã hóa dữ liệu khi lưu trữ

- Áp dụng cho block storage, file storage, object storage, database và backup.
- Có thể dùng khóa do nhà cung cấp quản lý hoặc khóa do khách hàng quản lý.
- Nên bật mã hóa mặc định cho tài nguyên lưu trữ mới.
- Kết hợp versioning, object lock hoặc immutable backup cho dữ liệu quan trọng.

Mã hóa dữ liệu khi xử lý

- Hướng tới bảo vệ dữ liệu ngay cả khi đang được xử lý trong bộ nhớ.
- Thường gắn với khái niệm confidential computing hoặc trusted execution environment.
- Phù hợp dữ liệu rất nhạy cảm: tài chính, y tế, chính phủ, mô hình AI riêng tư.
- Cần đánh giá chi phí, hiệu năng và mức hỗ trợ của nền tảng.

Dịch vụ quản lý khóa và HSM

- Key Management Service giúp tạo, lưu trữ, xoay vòng và kiểm soát khóa mã hóa.
- Hardware Security Module cung cấp môi trường bảo vệ khóa mức phần cứng.
- Phân quyền sử dụng khóa phải tách biệt với phân quyền dữ liệu.
- Mất quyền quản lý khóa có thể làm mất khả năng truy cập dữ liệu.

Quản lý secret

- Secret gồm mật khẩu, token, API key, certificate, private key và connection string.
- Không lưu secret trực tiếp trong mã nguồn, image, log hoặc file cấu hình công khai.
- Dùng secret manager, phân quyền theo ứng dụng, xoay vòng định kỳ.
- Theo dõi truy cập secret và cảnh báo khi có hành vi bất thường.

Ngăn ngừa thất thoát dữ liệu

- Phát hiện dữ liệu nhạy cảm trong lưu trữ, email, log hoặc hệ thống chia sẻ.
- Thiết lập chính sách chặn chia sẻ công khai hoặc tải xuống trái phép.
- Áp dụng watermarking, cảnh báo và kiểm soát xuất dữ liệu nếu cần.
- DLP hiệu quả cần đi kèm phân loại dữ liệu và quản lý quyền.

Sao lưu bất biến và chống ransomware

- Ransomware có thể mã hóa dữ liệu chính và cố gắng xóa backup.
- Backup cần tách quyền, tách tài khoản, tách vùng hoặc tách môi trường.
- Sử dụng versioning, retention lock, immutable storage và kiểm thử khôi phục.
- Backup chỉ có ý nghĩa khi có thể phục hồi đúng thời gian yêu cầu.

4. Bảo mật mạng đám mây

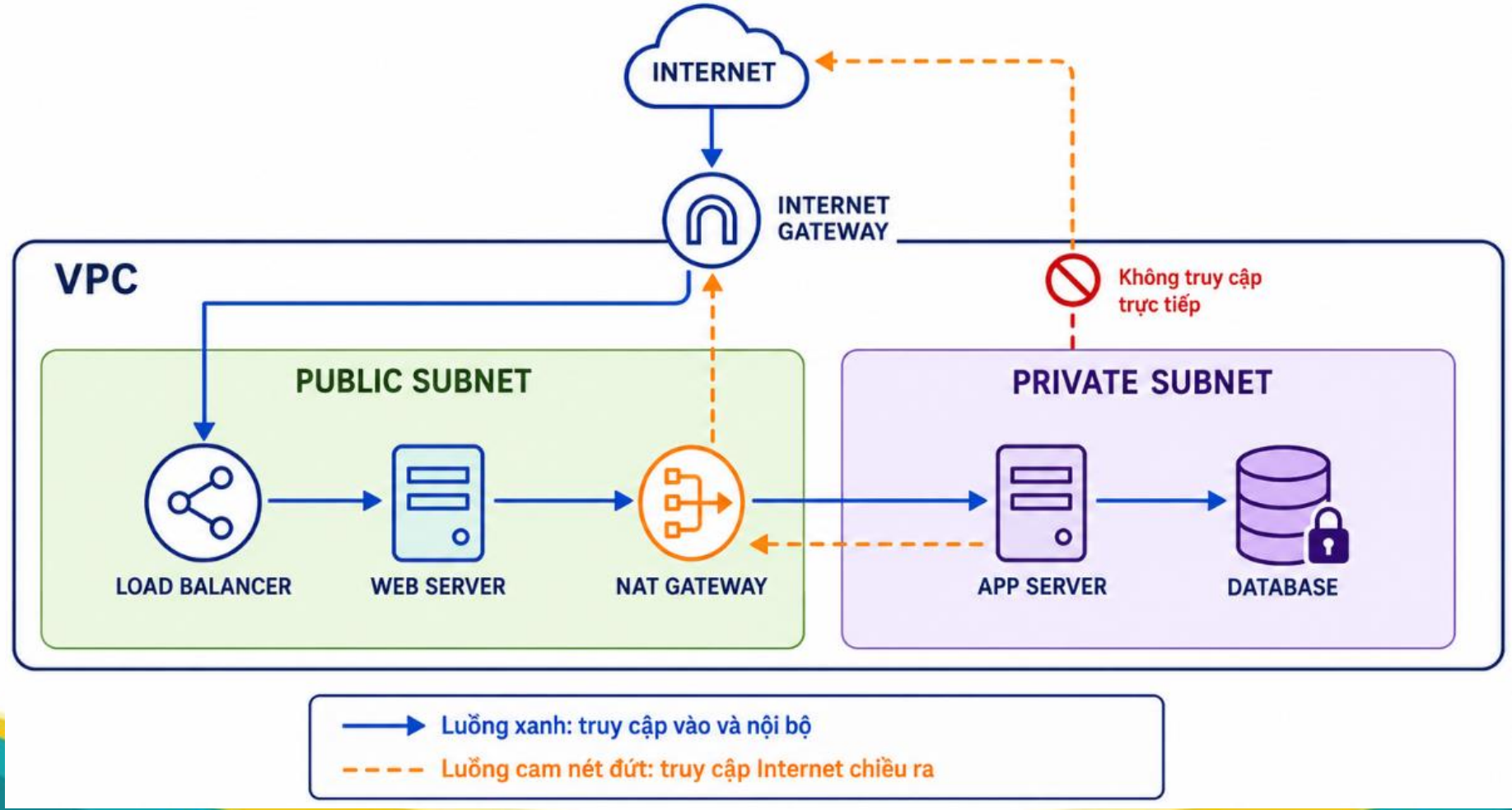
- Mạng cloud cần phân đoạn rõ ràng, chỉ mở đúng luồng cần thiết và có lớp bảo vệ ở biên.



Phân đoạn mạng

- Chia mạng theo chức năng: public, private, database, management.
- Giới hạn đường đi giữa các lớp ứng dụng.
- Chỉ thành phần cần public mới được đưa ra Internet.
- Dùng subnet, route table, firewall và security policy để kiểm soát lưu lượng.

Public subnet và Private subnet



Tiêu chí	Public Subnet (Mạng con Công khai)	Private Subnet (Mạng con Riêng tư)
Kết nối Internet	Có thể truy cập **2 chiều** (Gửi ra và Nhận vào từ Internet).	Mặc định **không thể truy cập trực tiếp** từ/đến Internet.
Bảng định tuyến (Route Table)	Có định tuyến trực tiếp (0.0.0.0/0) tới **Internet Gateway (IGW)**.	Không có route tới IGW. Muốn ra Internet phải qua **NAT Gateway** / Proxy.
Địa chỉ IP	Các tài nguyên (EC2/VM) bắt buộc phải có **Public IP** (hoặc Elastic IP).	Chỉ có **Private IP** nội bộ. Không thể gắn Public IP để mở ra ngoài.
Vai trò chính	Chứa các dịch vụ cần giao tiếp trực tiếp với người dùng công cộng.	Chứa dữ liệu nhạy cảm, logic nghiệp vụ cốt lõi cần giấu kín.
Tài nguyên điển hình	Web Servers, Load Balancers (ALB/NLB), Bastion Hosts (Jump box), API Gateways.	Databases (RDS, PostgreSQL), Application Servers (Backend), Internal Caches (Redis).

Mô hình Thực tế: Kiến trúc 3 Lớp (3-Tier Architecture)

Trong thiết kế hạ tầng an toàn chuẩn doanh nghiệp, người ta luôn kết hợp cả hai loại Subnet này theo mô hình phân tầng:

1.Lớp Web/Presentation (Public Subnet): Đặt Load Balancer (ALB) hoặc Reverse Proxy để hứng toàn bộ lưu lượng truy cập từ Internet.

2.Lớp Application/Logic (Private Subnet 1): Đặt các máy chủ App (Node.js, Java, Python). Chỉ nhận truy cập được chuyển tiếp từ Load Balancer ở Lớp Web.

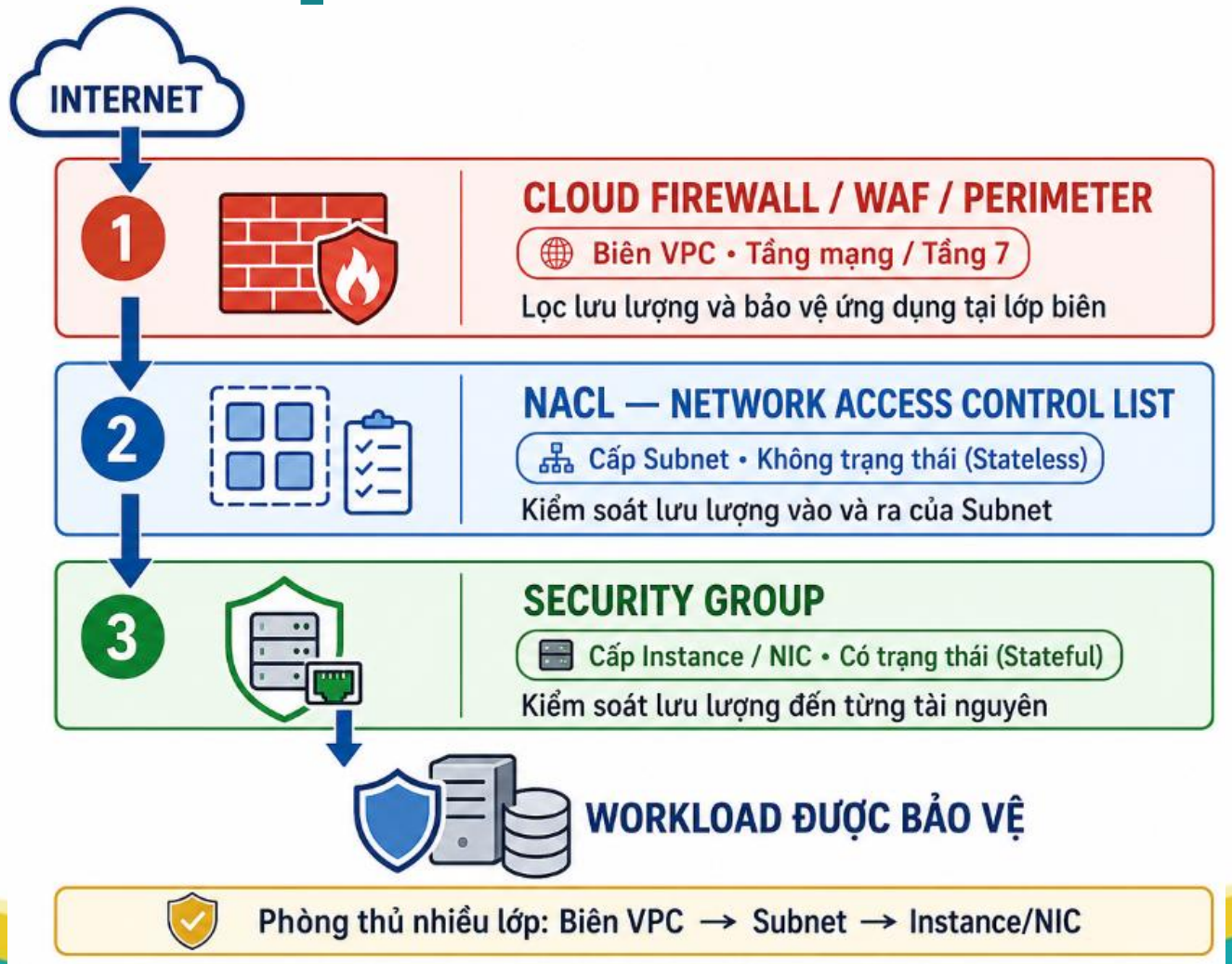
3.Lớp Database/Data (Private Subnet 2): Đặt các cụm CSDL (MySQL, MongoDB) ở một Private Subnet hoàn toàn biệt lập. Chỉ cho phép Lớp App kết nối tới qua các cổng nội bộ cố định.

Quy tắc bảo mật cốt lõi: Luôn áp dụng nguyên tắc **Least Privilege** cho hạ tầng mạng — Tất cả mọi thứ phải nằm ở **Private Subnet** theo mặc định, ngoại trừ các thành phần bắt buộc phải tiếp xúc với Internet mới được đưa ra **Public Subnet**.

Security Group, NACL và Firewall

- Trong hạ tầng mạng máy tính và điện toán đám mây (Cloud Networking), **Security Group**, **NACL (Network Access Control List)** và **Firewall** đều là các bức tường lửa kiểm soát lưu lượng truy cập (Inbound và Outbound).
- Tuy nhiên, chúng hoạt động ở các tầng khác nhau trong mô hình mạng và áp dụng các cơ chế bảo mật hoàn toàn khác biệt.

Security Group, NACL và Firewall



Security Group, NACL và Firewall

Tiêu chí	Security Group (SG)	NACL (Network Access Control List)	Firewall (Next-Gen Firewall / WAF)
Phạm vi bảo vệ	**Cấp độ Máy ảo / NIC** (Virtual Interface/Instance).	**Cấp độ Subnet** (Mạng con).	**Cấp độ Toàn mạng (VPC/Perimeter) hoặc Tầng ứng dụng (Layer 7).**
Trạng thái (State)	**Stateful** (Có lưu trạng thái).	**Stateless** (Không lưu trạng thái).	**Stateful + Deep Packet Inspection (DPI).**
Quy tắc (Rules)	Chỉ hỗ trợ **ALLOW** (Cho phép). Mặc định Chặn tất cả.	Hỗ trợ cả **ALLOW** và **DENY** (Chặn).	Hỗ trợ **ALLOW, DENY, REJECT, LOG, DROP.**
Thứ tự ưu tiên	Đánh giá **TOÀN BỘ** các rules trước khi quyết định.	Đánh giá theo **Thứ tự số Rule (Rule Number)** từ thấp đến cao (Rule nhỏ hơn thắng).	Đánh giá theo Thứ tự ưu tiên (Priority/Policy Chain) hoặc theo đặc trưng chữ ký tấn công.
Vị trí tác động	Bảo vệ từng Instance cụ thể (Ví dụ: EC2, VM).	Bảo vệ toàn bộ tài nguyên thuộc một Subnet.	Đặt ở cổng vào/ra của VPC, Edge location, hoặc làm Appliance trung gian.

Mô hình phối hợp (Defense-in-Depth)

Để đạt hiệu quả an ninh tối đa, người ta không dùng đơn lẻ mà luôn kết hợp cả 3 thành phần theo nguyên tắc **Bảo vệ nhiều lớp (Defense-in-Depth)**:

- **Ở cấp độ VPC Perimeter:** Dùng **WAF/Cloud Firewall** để chắn các cuộc tấn công quét lỗ hổng ứng dụng, DDoS, và lọc URL độc hại.
- **Ở cấp độ Subnet:** Dùng **NACL** như một lớp lọc "thô". Giữ NACL mặc định (Allow All) và chỉ thêm các rule **DENY** cấp bách khi phát hiện các dải IP tấn công cần black-list.
- **Ở cấp độ Máy ảo:** Dùng **Security Group** làm lớp lọc "tinh". Áp dụng triệt để nguyên tắc **Least Privilege** — chỉ mở chính xác các port cần thiết (ví dụ: Port 443 cho Web, Port 22/3389 chỉ mở cho IP mạng nội bộ/Bastion Host).

Tường lửa ứng dụng Web

- Bảo vệ ứng dụng Web/API khỏi các mẫu tấn công phổ biến.
- Có thể lọc theo IP, quốc gia, header, URI, pattern và rate.
- Hỗ trợ giảm rủi ro SQL injection, XSS, bot và khai thác lỗ hổng ứng dụng.
- Không thay thế kiểm thử bảo mật và lập trình an toàn.

IDS/IPS trong cloud

- IDS phát hiện hành vi bất thường hoặc dấu hiệu tấn công.
- IPS có thể chặn hoặc phản ứng tự động với lưu lượng nguy hiểm.
- Trong cloud cần kết hợp log mạng, flow log, agent và dịch vụ phân tích.
- Cần giảm false positive để tránh mệt mỏi cảnh báo.

Bảo vệ chống DDoS

- DDoS làm cạn kiệt băng thông, tài nguyên hoặc năng lực xử lý ứng dụng.
- Cần dùng CDN, Anycast, rate limiting, WAF, autoscaling và dịch vụ chống DDoS.
- Thiết kế ứng dụng phân tán giúp hấp thụ lưu lượng tốt hơn.
- Kế hoạch ứng phó DDoS cần được chuẩn bị trước khi xảy ra sự cố.

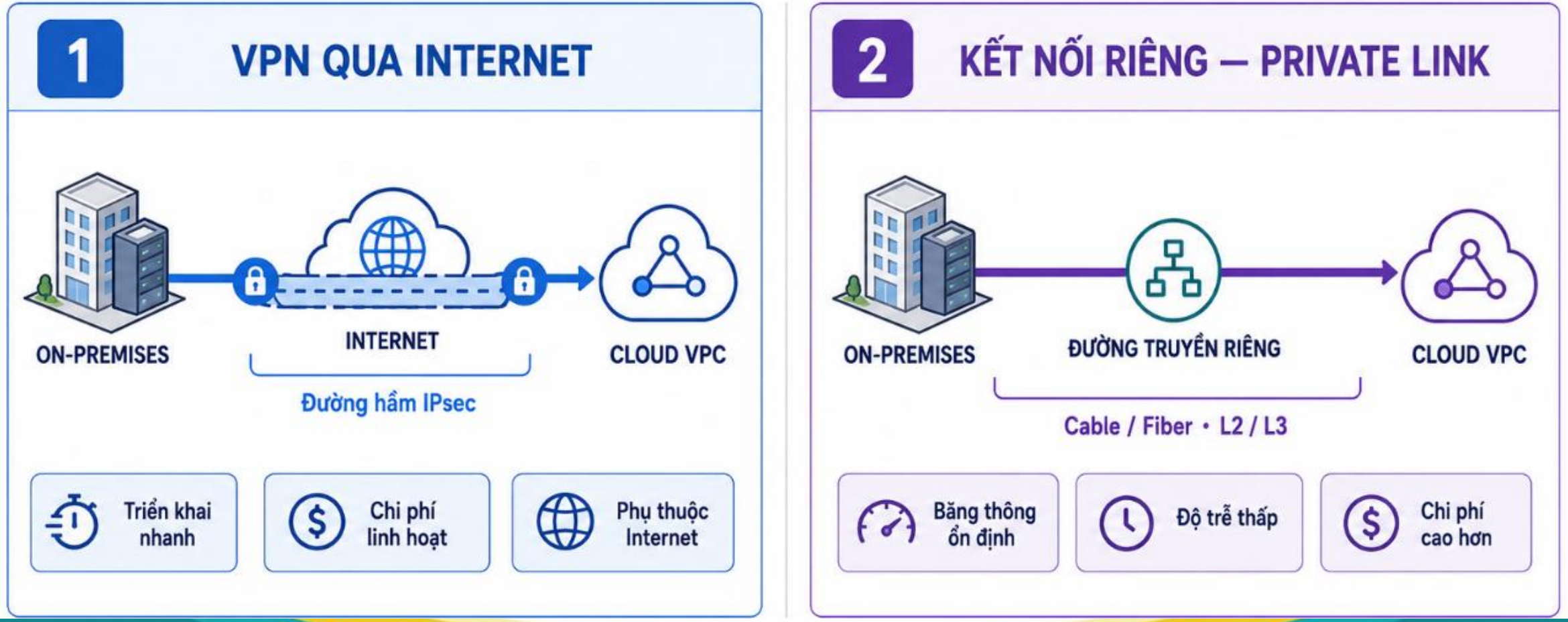
Bastion Host và truy cập quản trị

- Bastion Host là điểm trung gian kiểm soát truy cập quản trị vào mạng private.
- Hạn chế mở SSH/RDP trực tiếp từ Internet đến mọi máy chủ.
- Bật MFA, ghi log phiên truy cập và chỉ cho phép nguồn tin cậy.
- Ưu tiên dịch vụ quản trị không cần mở cổng public nếu nền tảng hỗ trợ.

VPN và kết nối riêng

- Để kết nối an toàn giữa mạng On-Premises (Trung tâm dữ liệu nội bộ/Văn phòng) với mạng Cloud (VPC/VNet), hoặc giữa các trụ sở chi nhánh với nhau, doanh nghiệp có hai lựa chọn kiến trúc mạng chính: **VPN (Virtual Private Network)** và **Kết nối Riêng (Dedicated/Private Connection)**.
- Dù cùng phục vụ mục tiêu mở rộng mạng nội bộ lên Cloud, hai phương thức này có sự khác biệt rõ rệt về hạ tầng, băng thông, độ trễ và chi phí.

VPN và kết nối riêng



Bảng So sánh Cốt lõi: VPN vs. Kết nối Riêng

Tiêu chí	Site-to-Site VPN	Kết nối Riêng chuyên dụng (Dedicated Connection)
Bản chất đường truyền	Tạo đường ống mã hóa đi qua **mạng Internet công cộng**.	Đường dây cáp quang vật lý **kết nối trực tiếp** (Bỏ qua Internet).
Tên dịch vụ Cloud	AWS Site-to-Site VPN, GCP Cloud VPN, Azure VPN Gateway.	**AWS Direct Connect (DX)**, **GCP Interconnect**, **Azure ExpressRoute**.
Độ tin cậy & Độ trễ	Phụ thuộc vào chất lượng mạng Internet (độ trễ biến động, có thể rớt gói).	Độ trễ cực thấp, ổn định tuyệt đối (Cam kết SLA chất lượng mạng).
Băng thông (Bandwidth)	Giới hạn (thường tối đa 1.25 đến 3 Gbps mỗi tunnel).	Rất lớn (Tùy chọn linh hoạt từ 50 Mbps đến 100 Gbps).
Bảo mật	Mã hóa mạnh mẽ ở tầng mạng (**IPsec / TLS**).	**Bảo mật vật lý** (Lưu lượng hoàn toàn tách biệt với Internet công cộng).
Thời gian triển khai	Nhanh chóng (**vài phút đến vài giờ** qua cấu hình phần mềm).	Lâu hơn (**vài tuần đến vài tháng** do cần kéo cáp và phối hợp với Telco).
Chi phí	**Rất rẻ** (Trả theo giờ sử dụng Gateway + phí Data Transfer out).	**Cao** (Chi phí cổng kết nối cố định + chi phí thuê kênh của đối tác Telco).

Zero Trust trong môi trường cloud

- Trong môi trường Điện toán Đám mây (Cloud), ranh giới mạng truyền thống (Perimeter-based Security) — nơi hệ thống tin tưởng tuyệt đối vào bất kỳ kết nối nào nằm bên trong tường lửa nội bộ — đã hoàn toàn bị xóa bỏ. Dữ liệu, ứng dụng và người dùng hiện nay phân tán ở khắp mọi nơi.
- Mô hình **Zero Trust** ra đời như một triết lý an ninh mạng cốt lõi cho Cloud, thay đổi hoàn toàn tư duy từ *"Tin tưởng nhưng kiểm tra" (Trust, but Verify)* sang **"Không bao giờ tin tưởng, Luôn luôn xác minh" (Never Trust, Always Verify)**.

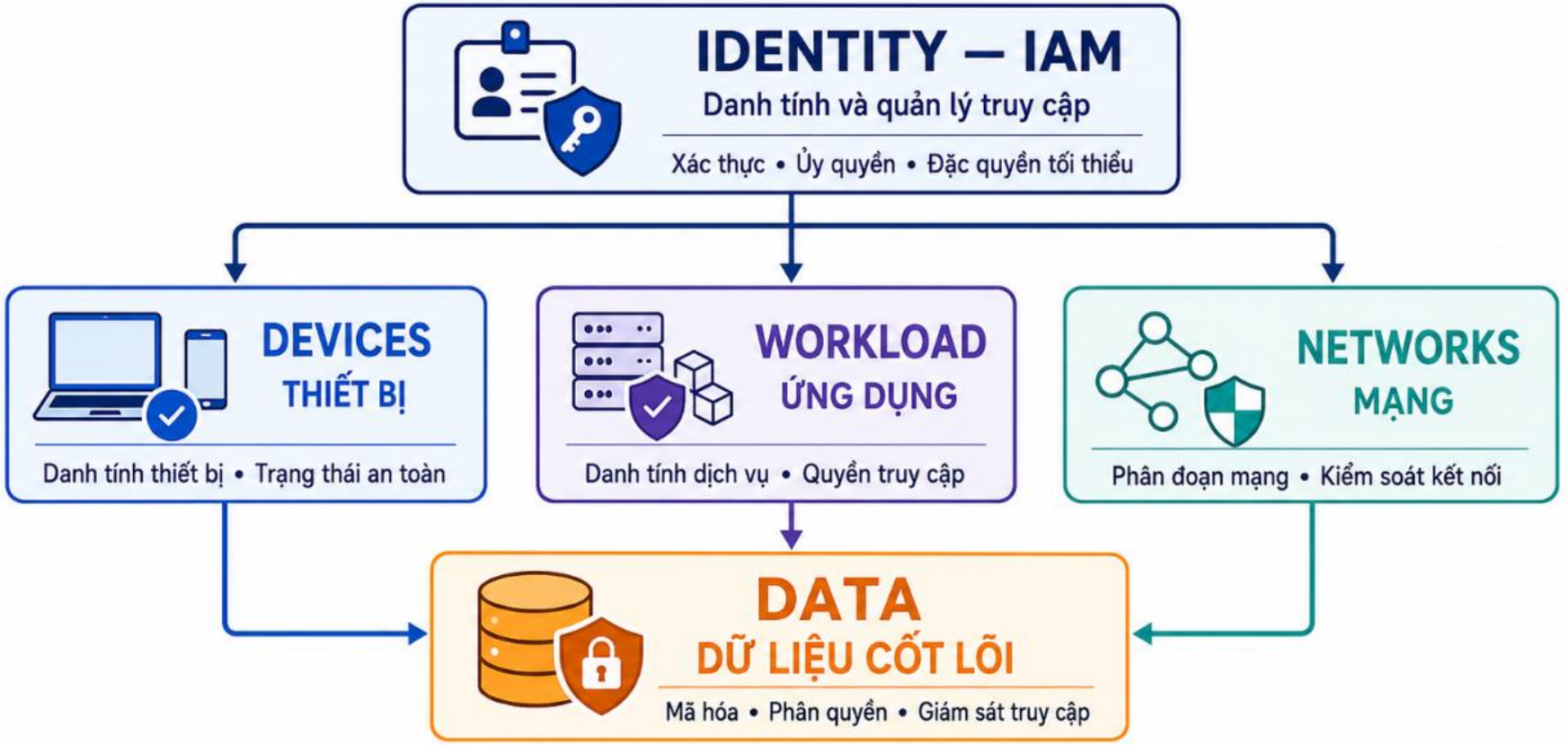
Zero Trust trong môi trường cloud

- Không mặc định tin cậy chỉ vì người dùng nằm trong mạng nội bộ.
- Luôn xác minh danh tính, thiết bị, ngữ cảnh và quyền truy cập.
- Áp dụng quyền tối thiểu, phân đoạn nhỏ và giám sát liên tục.
- Phù hợp môi trường hybrid, multi-cloud và làm việc từ xa.

Ba Nguyên tắc Trụ cột của Zero Trust trên Cloud

- **Xác minh chủ động & Triệt để (Verify Explicitly):** Luôn luôn xác thực và cấp quyền dựa trên tất cả các điểm dữ liệu khả dụng: danh tính người dùng, vị trí, thiết bị, dịch vụ/workload, phân loại dữ liệu và các bất thường theo thời gian thực.
- **Sử dụng quyền tối thiểu (Use Least Privileged Access):** Giới hạn quyền hạn truy cập của người dùng và dịch vụ với các cơ chế **Just-In-Time (JIT)** và **Just-Enough-Access (JEA)**, kết hợp chính sách thích ứng dựa trên rủi ro (Risk-based Adaptive Policies).
- **Giả định hệ thống đã bị xâm nhập (Assume Breach):** Thiết kế hạ tầng với tâm thế kẻ tấn công đã nằm sẵn bên trong mạng. Thực hiện phân đoạn mạng vi mô (**Micro-segmentation**), mã hóa toàn bộ dữ liệu (End-to-End), và liên tục giám sát, phát hiện mối đe dọa theo thời gian thực.

Các Trụ cột Triển khai Zero Trust trên Cloud (Zero Trust Domains)



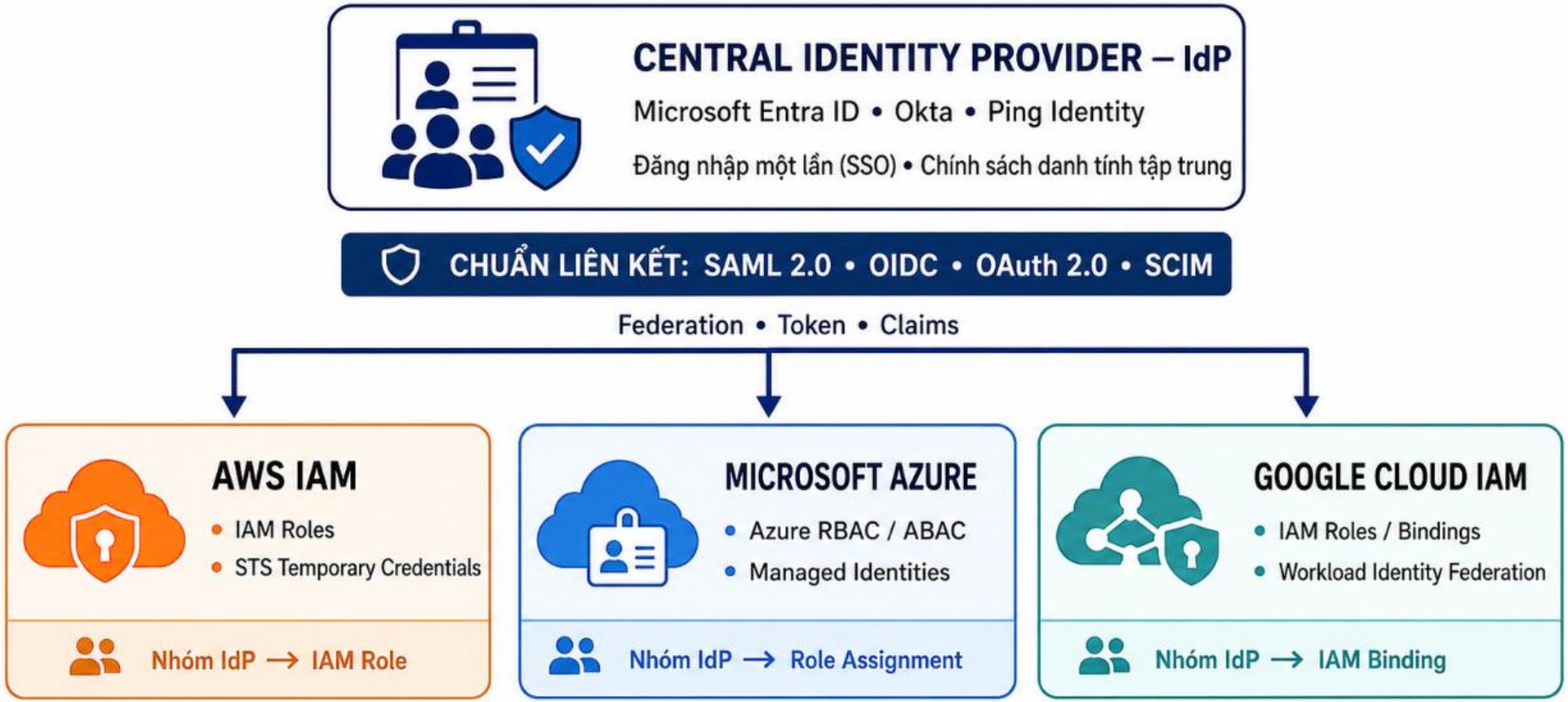
So sánh: Security Truyền thống vs. Zero Trust trên Cloud

Tiêu chí	Mô hình Truyền thống (Castle & Moat)	Mô hình Zero Trust trên Cloud
Triết lý	Tin tưởng tất cả thiết bị/người dùng nằm *bên trong* mạng nội bộ.	Không tin tưởng bất kỳ ai/thành phần nào, dù nằm trong hay ngoài mạng.
Ranh giới (Perimeter)	Dựa trên vị trí mạng vật lý / IP Subnet / VPN.	Dựa trên **Danh tính (Identity)**, **Thiết bị** và **Ngữ cảnh truy cập**.
Ủy quyền (Authorization)	Cấp quyền rộng rãi một lần khi đăng nhập mạng.	Kiểm tra & cấp quyền **liên tục theo thời gian thực (Continuous Verification)**.
Luồng dịch chuyển (Lateral Movement)	Kẻ tấn công dễ dàng di chuyển ngang trong mạng khi đã vượt qua VPN/Firewall.	Bị chặn hoàn toàn nhờ **Phân đoạn vi mô (Micro-segmentation)**.

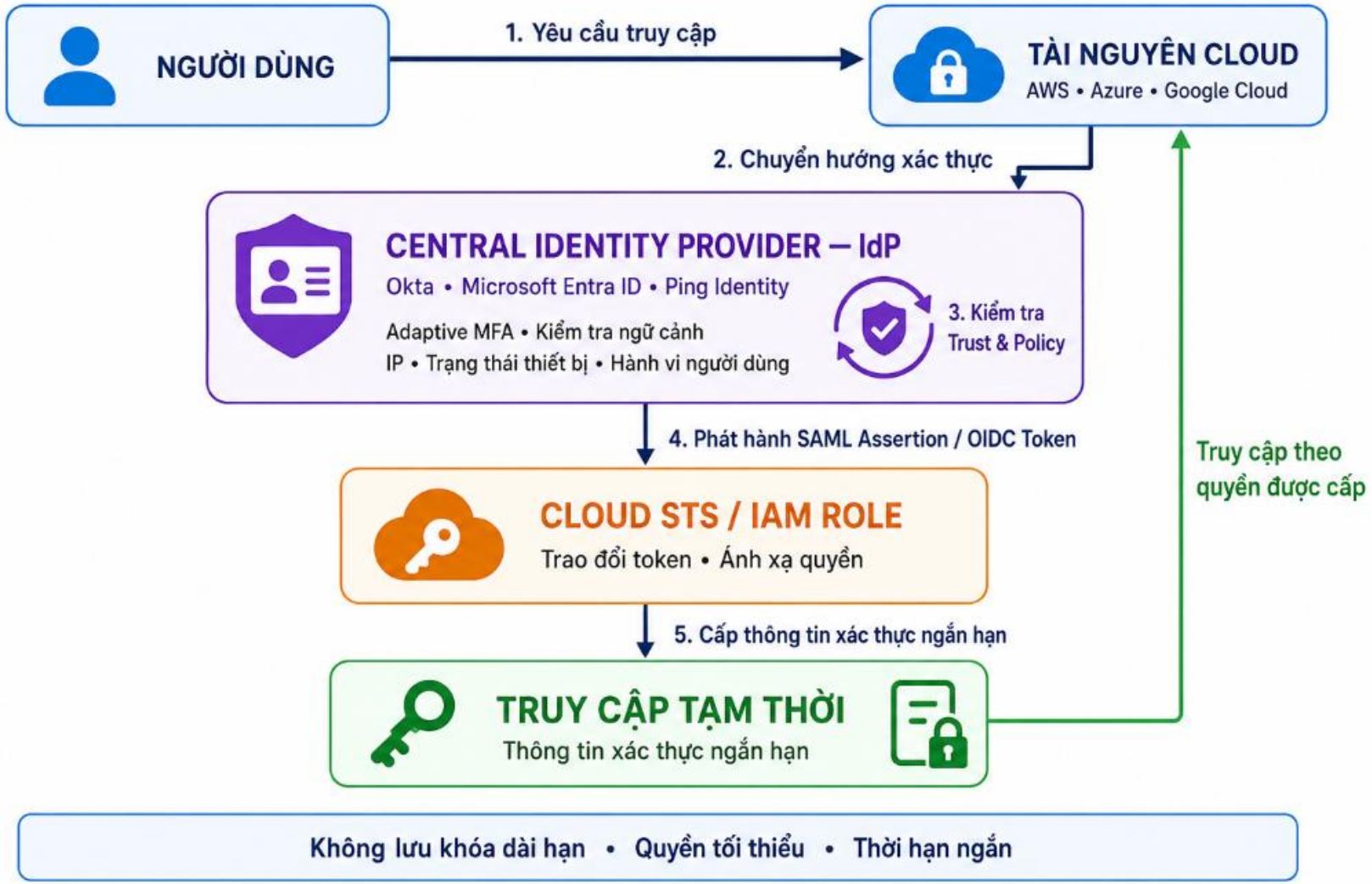
Quản lý Danh tính Multi-Cloud trong Zero Trust

- Triển khai mô hình **Zero Trust** trên môi trường **Multi-Cloud** (kết hợp các nền tảng AWS, Google Cloud, Microsoft Azure, AliCloud...) đặt ra những bài toán vô cùng phức tạp.
- Trong Zero Trust, **Danh tính (Identity) chính là ranh giới bảo mật mới (The New Perimeter)**. Tuy nhiên, việc mỗi nhà cung cấp Cloud sở hữu một hệ thống Identity and Access Management (IAM) độc lập, cơ chế xác thực riêng và cách thức định nghĩa chính sách khác nhau đã tạo ra những lỗ hổng an ninh nghiêm trọng nếu không có một kiến trúc **Quản lý Danh tính Tập trung (Federated Identity / SSO)** chuẩn mực.

Quản lý Danh tính Multi-Cloud trong Zero Trust



Kiến trúc Xác thực Người dùng (Human Identity Federation)



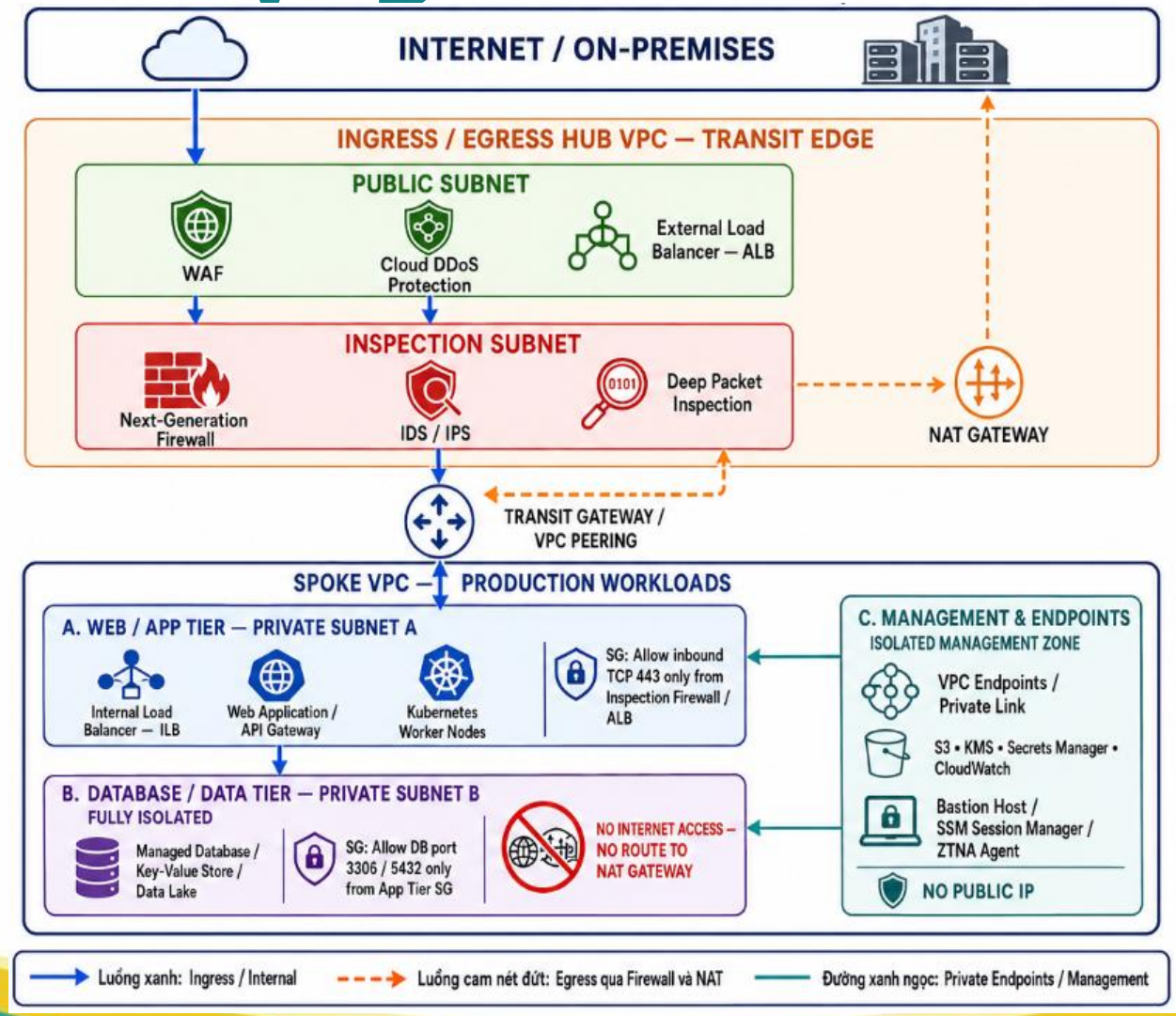
Kiến trúc mạng cloud an toàn mẫu

- **Kiến trúc Mạng Cloud An toàn Mẫu (Secure Cloud Network Reference Architecture)** được thiết kế theo mô hình **Chuẩn Enterprise / Multi-Tier**, tuân thủ nghiêm ngặt các nguyên tắc **Zero Trust**, **Defense-in-Depth (Bảo vệ nhiều lớp)** và khung chuẩn an ninh mạng của AWS/Azure/GCP (Well-Architected Framework).
- Kiến trúc này tách biệt hoàn toàn giữa **Luồng mạng kiểm soát vào/ra (Ingress/Egress Edge)**, **Tầng quản trị (Management)** và **Tầng ứng dụng/Dữ liệu (Workload tiers)** thông qua mô hình **Hub-and-Spoke** kết hợp **Phân đoạn vi mô (Micro-segmentation)**.

UTH UNIVERSITY OF TRANSPORT HOCHIMINH CITY

TRƯỜNG ĐẠI HỌC GIAO THÔNG VẬN TẢI THÀNH PHỐ HỒ CHÍ MINH

Kiến trúc mạng cloud an toàn mẫu



5. Bảo mật khối lượng công việc

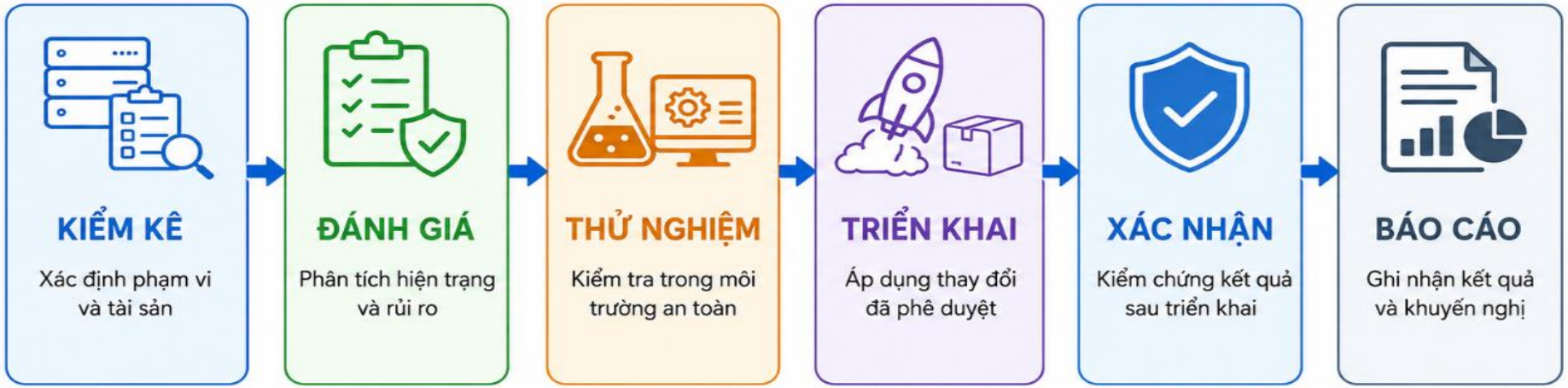
- Máy ảo, container, Kubernetes, serverless và API đều cần hardening, quét lỗ hổng và giám sát runtime.



Bảo mật máy ảo

- Sử dụng image chuẩn, nguồn tin cậy và cập nhật định kỳ.
- Tắt dịch vụ không cần thiết và đóng cổng không sử dụng.
- Dùng endpoint protection/EDR nếu phù hợp.
- Không lưu secret trong máy ảo không được quản lý.
- Ghi log hệ điều hành và gửi log ra hệ thống tập trung.

Quản lý bản vá



- Bản vá cần ưu tiên theo mức độ nghiêm trọng và tài sản bị ảnh hưởng.
- Nên có môi trường thử nghiệm trước khi cập nhật sản xuất.
- Tự động hóa giúp giảm bỏ sót nhưng cần lịch bảo trì và rollback.
- Không chỉ vá hệ điều hành; cần vá middleware, runtime, thư viện và container image.

Quét lỗ hổng

- Quét máy ảo, container image, thư viện phần mềm, IaC template và cấu hình cloud.
- Phân loại lỗ hổng theo mức độ nghiêm trọng, khả năng khai thác và mức độ phơi lộ.
- Không chỉ phát hiện; cần có quy trình xử lý và xác nhận đã khắc phục.
- Kết hợp quét định kỳ và quét trong pipeline CI/CD.

Bảo mật ảnh máy và ảnh container

- Dùng base image nhỏ, chính thức và được cập nhật.
- Không đưa secret, private key hoặc file nhạy cảm vào image.
- Ký số image, kiểm tra nguồn gốc và quét lỗ hổng trước khi triển khai.
- Dùng registry riêng có phân quyền và log truy cập.

Bảo mật Kubernetes

- Áp dụng RBAC cho cluster và namespace.
- Không chạy container với quyền root nếu không cần.
- Dùng NetworkPolicy để giới hạn giao tiếp giữa pod.
- Quản lý Secret đúng cách và mã hóa dữ liệu nhạy cảm.
- Cập nhật control plane, node và add-on định kỳ.

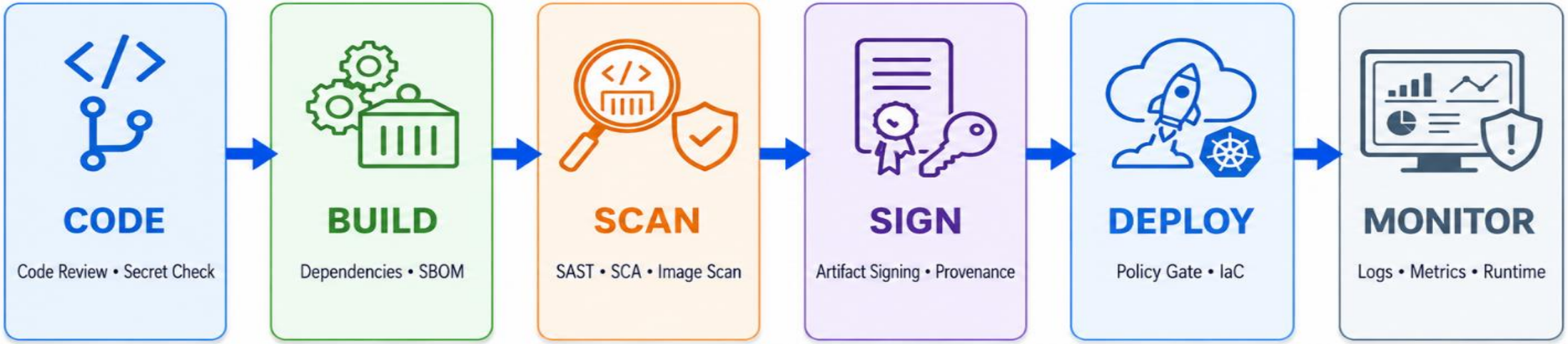
Bảo mật serverless

- Mỗi function nên có quyền tối thiểu cho đúng tài nguyên cần dùng.
- Kiểm soát input, event source và timeout để tránh lạm dụng.
- Không lưu secret trong biến môi trường nếu không được mã hóa/quản lý đúng.
- Theo dõi log, lỗi, số lần gọi và chi phí bất thường.
- Kiểm soát phụ thuộc thư viện và package.

Bảo mật API Gateway

- API Gateway là điểm vào cho ứng dụng, microservices và serverless.
- Cần xác thực, phân quyền, rate limiting, schema validation và logging.
- Không đưa thông tin nhạy cảm vào URL hoặc response lỗi.
- Kết hợp WAF, token, mTLS hoặc signed request theo yêu cầu hệ thống.

Bảo vệ chuỗi cung ứng trong DevSecOps



- Kiểm soát quyền repository và pipeline.
- Quét mã nguồn, thư viện, container image và IaC.
- Ký số artifact và xác minh trước khi triển khai.
- Tách môi trường dev/test/prod và dùng phê duyệt cho production.

6. Giám sát và ứng phó sự cố

Không có log và cảnh báo, tổ chức sẽ không biết điều gì đang xảy ra trong môi trường cloud.



Nhật ký kiểm toán cloud

- Ghi lại ai đã làm gì, lúc nào, từ đâu và trên tài nguyên nào.
- Rất quan trọng với hoạt động IAM, thay đổi cấu hình, tạo/xóa tài nguyên và truy cập dữ liệu.
- Log cần được lưu ở nơi khó sửa/xóa và có thời gian lưu giữ phù hợp.
- Cần cảnh báo cho sự kiện nhạy cảm: tắt logging, xóa backup, tạo key mới, mở public access.

Log hệ thống, ứng dụng và mạng

- Log hệ điều hành: đăng nhập, service, process, lỗi hệ thống.
- Log ứng dụng: request, error, giao dịch, hành vi người dùng.
- Log mạng: flow, firewall, WAF, DNS, load balancer.
- Cần chuẩn hóa định dạng, timestamp, múi giờ và liên kết định danh.

Metrics và cảnh báo

- Metrics đo trạng thái hệ thống: CPU, RAM, disk, request, latency, error rate.
- Cảnh báo nên dựa trên ngưỡng kỹ thuật và hành vi bất thường.
- Cảnh báo cần phân cấp mức độ và người chịu trách nhiệm xử lý.
- Tránh quá nhiều cảnh báo gây mệt mỏi và bỏ sót sự cố thật.

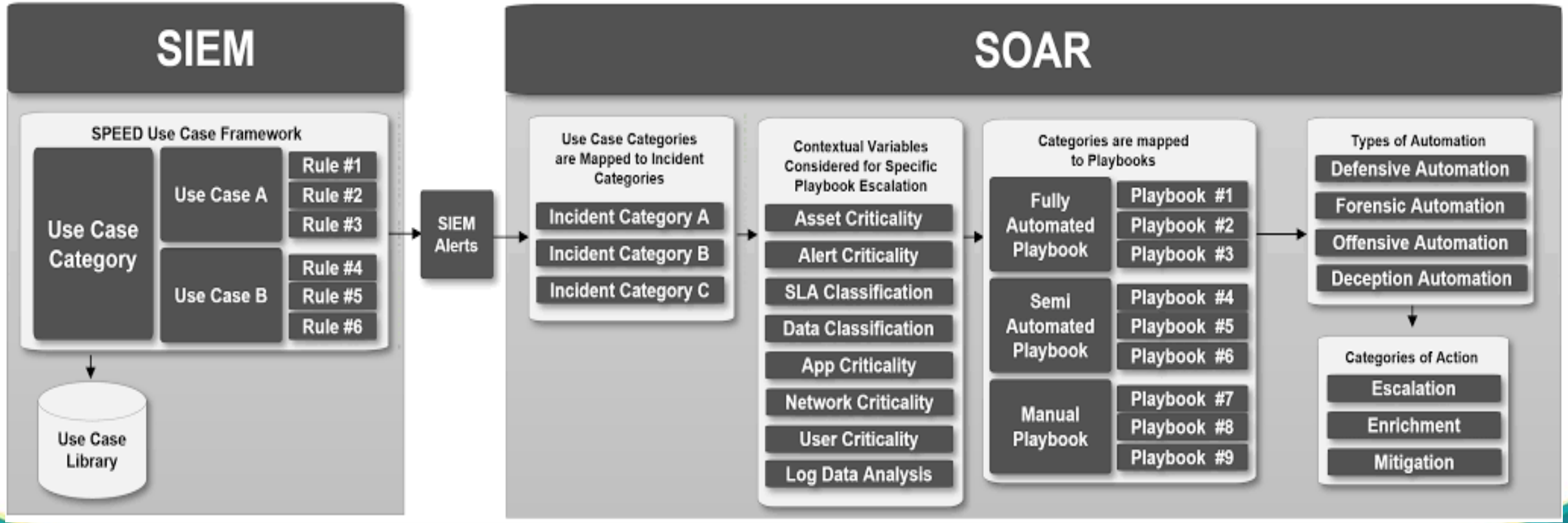
Theo dõi phân tán- Distributed tracing

- Theo dõi đường đi của một request qua nhiều service.
- Hữu ích với microservices, API gateway, serverless và hệ thống phân tán.
- Giúp xác định service nào gây chậm, lỗi hoặc bất thường.
- Kết hợp với log và metrics để tạo khả năng quan sát đầy đủ.

SIEM và SOAR

- Trong trung tâm vận hành an ninh mạng (SOC), **SIEM** và **SOAR** là bộ đôi công nghệ cốt lõi đóng vai trò như "Bộ não" và "Đôi tay" của hệ thống phòng thủ.
- Nếu như **SIEM** chịu trách nhiệm thu thập, phân tích và phát hiện các mối đe dọa từ hàng triệu dòng Log, thì **SOAR** tiếp quản các cảnh báo đó để tự động hóa quy trình phản ứng, điều tra và cô lập sự cố trong vài giây.

SIEM và SOAR



Mô hình phối hợp: SIEM phát hiện cảnh báo, SOAR thực thi Playbook phản ứng. Nguồn: Correlated Security

Bảng So sánh Chi tiết: SIEM vs. SOAR

Tiêu chí	SIEM (Security Information & Event Management)	SOAR (Security Orchestration, Automation & Response)
Vai trò chính	**Phát hiện (Detection)** & Giám sát tập trung.	**Phản ứng (Response)** & Tự động hóa quy trình.
Đầu vào (Input)	Dữ liệu thô (Raw Logs, Events, Flows, Metrics).	Cảnh báo (Alerts / Incidents) đã qua xử lý từ SIEM, EDR, Threat Intel.
Đầu ra (Output)	Cảnh báo an ninh (Security Alerts), Dashboards, Reports.	Hành động khắc phục (Actions), Kịch bản tự động (Playbooks), Tickets.
Cơ chế cốt lõi	Rule-based Correlation, UEBA (Behavior Analytics), Log Parsing.	API Integrations, Automated Workflows (Playbooks), Machine Learning.
Khả năng chủ động	Tương đối thụ động (Chỉ cảnh báo cho Chuyên viên SOC biết).	**Chủ động** (Tự động can thiệp vào hệ thống để ngắt kết nối/chặn cuộc tấn công).
Giảm tải cho SOC	Dễ gây ra hiện tượng **Alert Fatigue** (Ngợp cảnh báo).	**Khắc phục Alert Fatigue** nhờ tự động lọc cảnh báo rác và xử lý sự cố mức Tier 1.

Xu hướng Hiện đại: Sự Hội tụ SIEM + SOAR + XDR

Trong những năm gần đây, ranh giới giữa SIEM và SOAR đang mờ dần:

•**Next-Gen SIEM / Cloud-Native SIEM:** Các giải pháp SIEM hiện đại (như Microsoft Sentinel, Google SecOps/Chronicle, Splunk Enterprise Security, Palo Alto Cortex XSIAM) đã **tích hợp sẵn tính năng SOAR native** bên trong nền tảng.

•**XDR (Extended Detection and Response):** Xu hướng gom chung phân tích dữ liệu Endpoint, Network, Cloud và tự động hóa phản ứng vào một nền tảng SaaS duy nhất, giúp doanh nghiệp không cần tốn quá nhiều công sức tích hợp SIEM và SOAR thủ công qua API.

Khuyên dùng cho SOC: Nếu hạ tầng của doanh nghiệp đang gặp tình trạng **Alert Fatigue** (Chuyên viên SOC tốn 70% thời gian chỉ để xử lý các cảnh báo giả hoặc các công việc lặp đi lặp lại như check IP/Hash), việc triển khai **SOAR** kết hợp với **Playbooks tự động hóa** là giải pháp tối ưu nhất để giảm chỉ số **MTTR (Mean Time to Respond)** từ nhiều giờ xuống tính bằng giây.

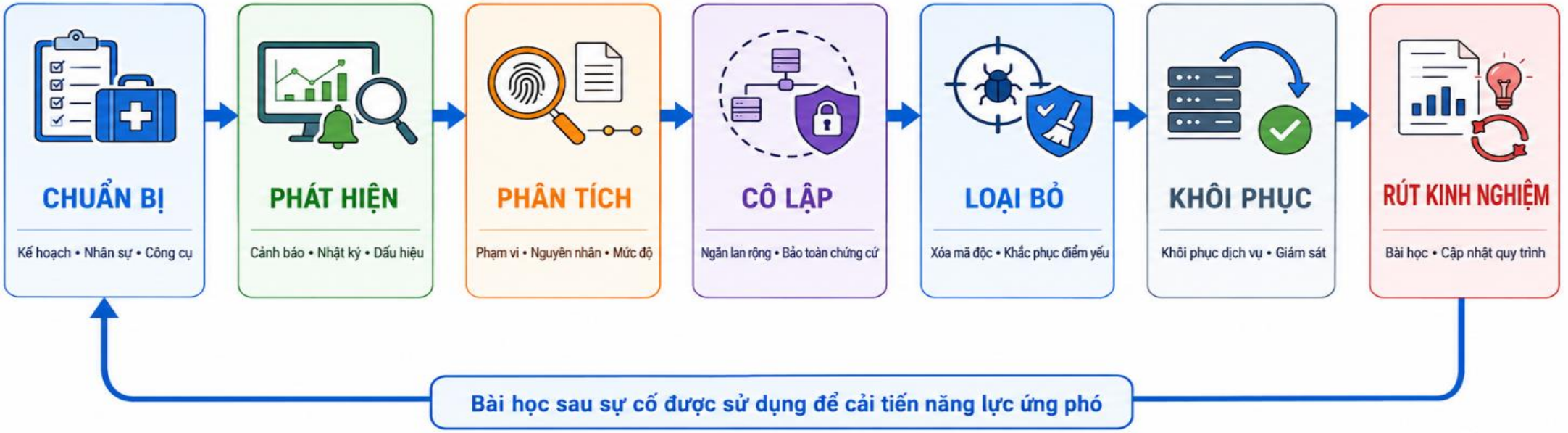
CSPM và quản lý tư thế bảo mật cloud

- **CSPM (Cloud Security Posture Management)** là nhóm giải pháp an ninh mạng tự động hóa việc phát hiện, đánh giá và khắc phục rủi ro cấu hình sai (Misconfiguration) cũng như các vi phạm tuân thủ trên toàn bộ hạ tầng Multi-Cloud (AWS, Azure, GCP...).
- Trong mô hình **Shared Responsibility Model** (Trách nhiệm dùng chung), nhà cung cấp Cloud chịu trách nhiệm bảo vệ hạ tầng vật lý ("Security OF the Cloud"), còn doanh nghiệp chịu trách nhiệm hoàn toàn cho cấu hình, dữ liệu và danh tính ("Security IN the Cloud"). CSPM ra đời chính là để giúp doanh nghiệp thực thi phần trách nhiệm này.

CSPM và quản lý tư thế bảo mật cloud

- CSPM kiểm tra cấu hình cloud so với chính sách và best practices.
- Phát hiện public bucket, security group mở rộng, tài khoản không MFA, mã hóa bị tắt.
- Giúp quản lý drift cấu hình trong môi trường nhiều tài khoản/dự án.
- Cần kết hợp với quy trình sửa lỗi và chủ sở hữu tài nguyên rõ ràng.

Quy trình ứng phó sự cố



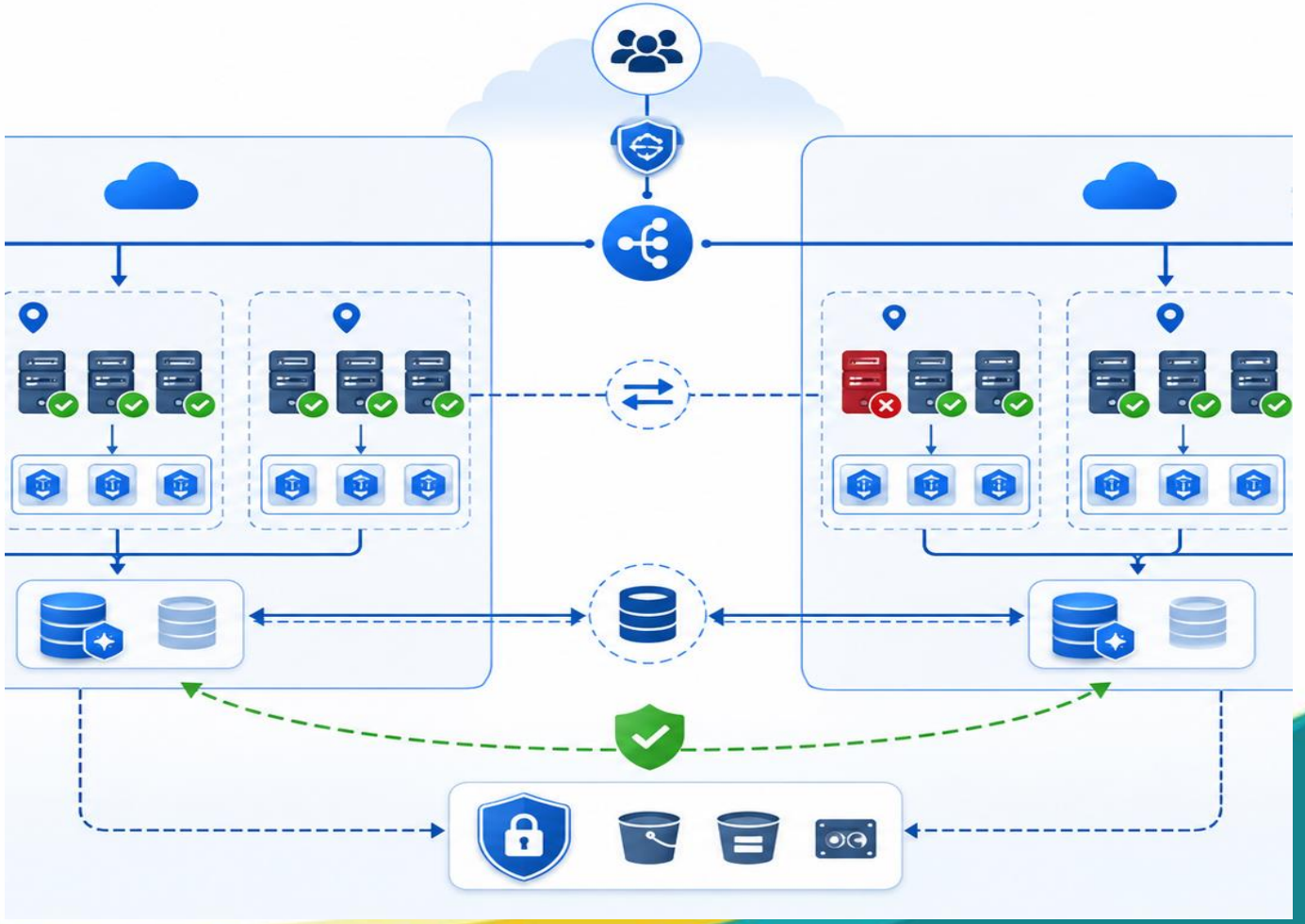
- Chuẩn bị trước tài khoản, log, playbook, kênh liên lạc và quyền khẩn cấp.
- Khi có sự cố cần cô lập nhanh nhưng tránh phá hủy bằng chứng.
- Sau khôi phục phải phân tích nguyên nhân gốc và cập nhật kiểm soát phòng ngừa.

Điều tra số trên cloud

- Thu thập log kiểm toán, log ứng dụng, snapshot, image và metadata tài nguyên.
- Bảo toàn bằng chứng: thời gian, tính toàn vẹn, quyền truy cập và chuỗi quản lý bằng chứng.
- Cloud cho phép snapshot nhanh nhưng cần quy trình tránh làm thay đổi hiện trường.
- Cần hiểu trách nhiệm và giới hạn dữ liệu mà nhà cung cấp có thể hỗ trợ.

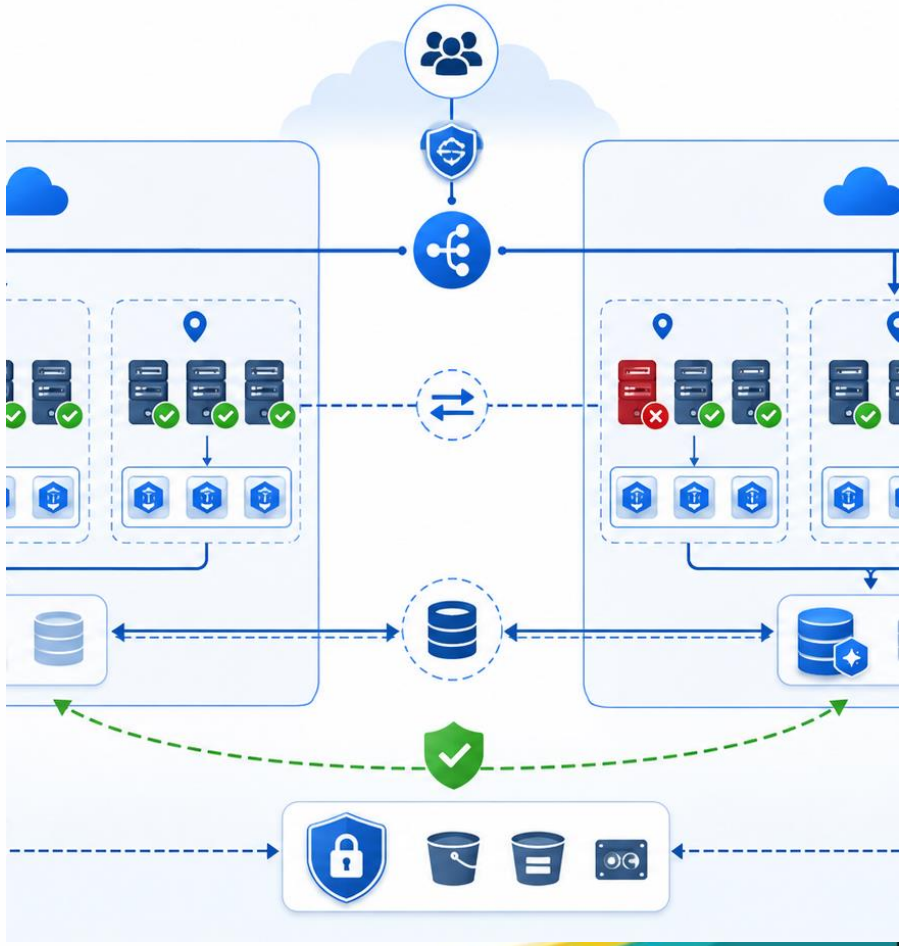
7. Sẵn sàng cao và phục hồi thảm họa

- Bảo mật không chỉ là chống xâm nhập, mà còn là bảo đảm dịch vụ phục hồi sau lỗi hoặc thảm họa.



Thiết kế sẵn sàng cao

- Loại bỏ điểm lỗi đơn ở Web, ứng dụng, database và network path.
- Triển khai nhiều Availability Zone khi hệ thống yêu cầu tính sẵn sàng cao.
- Dùng load balancer, health check, autoscaling và database replication.
- Kiểm thử failover định kỳ thay vì chỉ vẽ kiến trúc trên giấy.



Load balancing và Auto Scaling

- **Load Balancing** (Cân bằng tải) và **Auto Scaling** (Tự động mở rộng) là "bộ đôi hoàn hảo" cấu thành nên khả năng sẵn sàng cao (High Availability), độ tin cậy (Reliability) và tính co giãn (Elasticity) cho bất kỳ hệ thống CNTT / Cloud hiện đại nào.
- Nếu **Auto Scaling** đóng vai trò là "lực lượng sản xuất" tự động điều chỉnh số lượng máy chủ theo nhu cầu thực tế, thì **Load Balancer** chính là "người điều phối" phân phối lưu lượng truy cập một cách thông minh đến các máy chủ đó.

Load Balancing (Cân bằng tải)

•**Khái niệm:** Là cơ chế phân phối lưu lượng mạng hoặc truy cập ứng dụng tới một nhóm (pool) gồm nhiều máy chủ phía sau (Backend Instances/Pods).

•**Nhiệm vụ chính:**

1.Tránh quá tải: Đảm bảo không có máy chủ nào bị ngẽn do xử lý quá nhiều request trong khi các máy chủ khác đang rảnh rỗi.

2.Health Check (Kiểm tra sức khỏe): Liên tục kiểm tra trạng thái hoạt động của Backend. Nếu một máy chủ bị lỗi (Down), Load Balancer sẽ lập tức ngừng gửi traffic đến máy chủ đó.

3.SSL/TLS Termination: Giải mã kết nối HTTPS ngay tại Load Balancer để giảm tải tính toán mã hóa cho các máy chủ ứng dụng phía sau.

Auto Scaling (Tự động mở rộng)

- **Khái niệm:** Là tính năng tự động tăng hoặc giảm số lượng tài nguyên tính toán (VMs, Containers, Pods) dựa trên tải thực tế của hệ thống.
- **Hai chiều mở rộng:**
- **Horizontal Scaling (Scale Out / Scale In - Mở rộng hàng ngang):** Tăng hoặc giảm **số lượng** máy chủ (ví dụ: Tăng từ 2 VMs lên 10 VMs). *Đây là chiều mở rộng tiêu chuẩn kết hợp với Load Balancer.*
- **Vertical Scaling (Scale Up / Scale Down - Mở rộng hàng dọc):** Tăng hoặc giảm **cấu hình** của từng máy chủ (RAM, CPU). Thường yêu cầu Reboot và có giới hạn phần cứng.

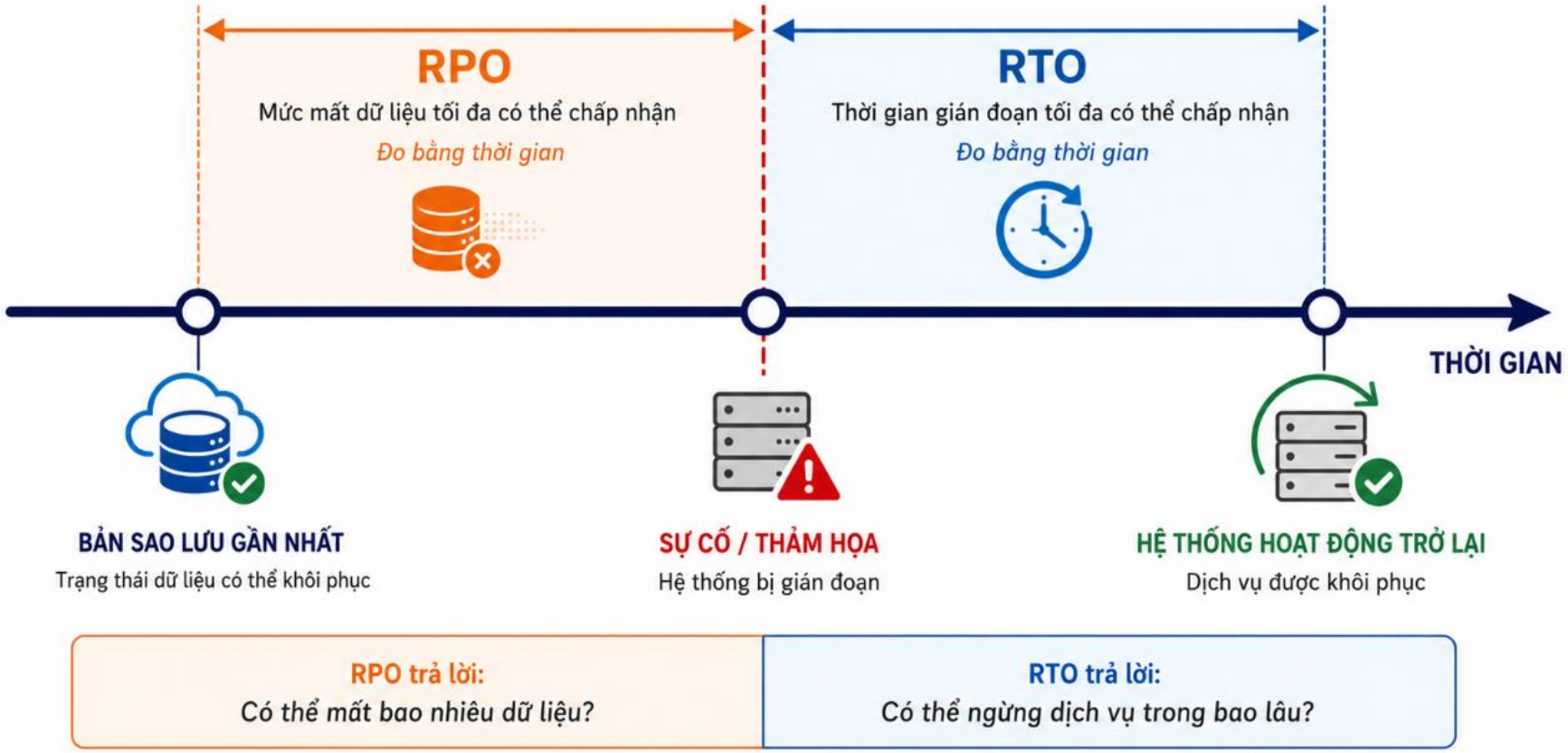
Sao lưu và nhân bản

- Backup phục vụ khôi phục khi mất dữ liệu, lỗi người dùng, ransomware hoặc sự cố hệ thống.
- Replication phục vụ sẵn sàng và chuyển đổi vùng nhanh hơn.
- Backup không thay thế replication; replication không thay thế backup.
- Cần chính sách retention, kiểm thử restore và bảo vệ backup khỏi xóa trái phép.

RTO và RPO

- Trong quản trị rủi ro, khắc phục thảm họa (**Disaster Recovery - DR**) và duy trì hoạt động kinh doanh (**Business Continuity Planning - BCP**), **RTO** và **RPO** là hai chỉ số kỹ thuật quan trọng nhất dùng để đo lường mức độ chịu đựng tổn thất của một hệ thống CNTT.
- Hai chỉ số này quyết định trực tiếp đến **mô hình kiến trúc hạ tầng** (Backup, Replication, High Availability) và **chi phí đầu tư** cho hệ thống.

RTO và RPO khôi phục sau thảm họa



RPO (Recovery Point Objective) - Mục tiêu Điểm Khắc phục

- **Định nghĩa:** Là **khoảng thời gian tối đa lượng dữ liệu bị mất** mà doanh nghiệp có thể chấp nhận được kể từ thời điểm sự cố xảy ra trở về quá khứ.
- **Câu hỏi cốt lõi:** *"Chúng ta chấp nhận mất bao nhiêu dữ liệu (tính theo phút, giờ, ngày) khi hệ thống chết?"*
- **Bản chất kỹ thuật:** Quyết định **tần suất sao lưu (Backup Frequency)** hoặc **cơ chế đồng bộ dữ liệu (Data Replication Strategy)**.

RTO (Recovery Time Objective)-Mục tiêu Thời gian Khắc phục

- **Định nghĩa:** Là **khoảng thời gian tối đa hệ thống được phép ngừng hoạt động (Downtime)** tính từ lúc sự cố xảy ra cho đến khi hệ thống được khôi phục hoàn toàn và đi vào vận hành bình thường.
- **Câu hỏi cốt lõi:** *"Hệ thống được phép 'chết' trong bao lâu mà doanh nghiệp chưa bị thiệt hại nghiêm trọng?"*
- **Bản chất kỹ thuật:** Quyết định **tốc độ khởi chạy lại hạ tầng (Failover Speed)**, tính tự động hóa và mức độ dự phòng của phần cứng/phần mềm.

So sánh RTO va RPO

Tiêu chí	RTO (Recovery Time Objective)	RPO (Recovery Point Objective)
Góc độ đo lường	Thời gian **gián đoạn dịch vụ** (Downtime).	Lượng **dữ liệu bị thất thoát** (Data Loss).
Hướng mốc thời gian	Nhìn về **Tương lai** (Từ lúc chết -> Khi sống lại).	Nhìn về **Quá khứ** (Từ lúc chết -> Lần lưu trữ gần nhất).
Tập trung vào	Hạ tầng, Server, Ứng dụng, Quy trình khôi phục.	Data, Database, File Systems, Transaction Logs.
Công nghệ quyết định	High Availability (HA), Multi-Region Failover, Auto-scaling, Automation Scripts.	Incremental Backup, Continuous Data Protection (CDP), Synchronous/Asynchronous Replication.
Ví dụ thực tế	Hệ thống sập lúc 10:00, RTO = 2 giờ $\rightarrow$ Bắt buộc đến 12:00 hệ thống phải chạy lại.	Hệ thống sập lúc 10:00, RPO = 15 phút $\rightarrow$ Mất tối đa dữ liệu từ 09:45 đến 10:00.

Mối tương quan giữa RTO/RPO, CHI PHÍ

CHI PHÍ TĂNG DẦN →

RTO / RPO GIẢM DẦN →

1 COLD SITE	2 WARM SITE	3 HOT SITE / ACTIVE-ACTIVE
		
RTO: Vài ngày đến vài tuần	RTO: Vài giờ	RTO: Vài giây hoặc gần bằng 0
RPO: Vài giờ đến vài ngày	RPO: Vài phút đến vài giờ	RPO: Gần bằng 0
$ — Thấp nhất	$$ — Trung bình	$$$$ — Cao nhất
Giải pháp điển hình: Sao lưu băng từ / Object Storage	Giải pháp điển hình: Pilot Light / Warm Standby	Giải pháp điển hình: Synchronous Replication
Hạ tầng dự phòng chưa sẵn sàng vận hành	Một phần hạ tầng luôn hoạt động	Hai môi trường hoạt động đồng thời

RTO và RPO càng thấp, mức đầu tư hạ tầng và vận hành càng cao.

Thực thi Kỹ thuật

- **Phân loại Ứng dụng (Business Impact Analysis - BIA):** Không thể áp dụng RTO/RPO = 0 cho toàn bộ hệ thống. Cần phân loại:
- **Core Banking / Payment Gateway:** Yêu cầu RTO ≈ 0, RPO = 0 (Bắt buộc dùng Active-Active / Multi-Region Synchronous).
- **Hệ thống ERP / CRM:** RTO < 1 giờ, RPO < 15 phút.
- **Hệ thống Quản lý Nội bộ / Chấm công:** RTO < 24 giờ, RPO < 1 ngày.
- **Thường xuyên Kiểm thử (DR Drill):** Mọi chỉ số RTO/RPO trên lý thuyết đều vô nghĩa nếu không được diễn tập thực tế. Cần tổ chức giả lập sự cố (Chaos Engineering / DR Testing) định kỳ để đo lường RTO thực tế của đội ngũ vận hành.

Các mô hình phục hồi thảm họa

Tiêu chí	Backup & Restore	Pilot Light	Warm Standby	Multi-Site Active-Active
RTO (Thời gian gián đoạn)	24h - Vài ngày	Vài chục phút	Vài phút	**~ 0 (Tức thì)**
RPO (Dữ liệu thất thoát)	Vài giờ - 24h	Vài giây - Phút	**~ 0**	**0 (Zero Data Loss)**
Mức độ phức tạp	Rất thấp	Trung bình	Khá cao	**Cực kỳ phức tạp**
Chi phí vận hành	**$** (Rẻ nhất)	**$ $**	**$ $ $**	**$ $ $ $** (Đắt nhất)
Cơ chế DB chính	Backup Snapshot	Asynchronous Replication	Asynchronous / Semi-Sync	**Synchronous Replication**
Can thiệp thủ công	100% Thủ công	Bán tự động (1-click)	Tự động / Bán tự động	**100% Tự động**

8. Quản trị, tuân thủ và thực hành

Quản trị tốt giúp bảo mật nhất quán trong môi trường nhiều tài khoản, nhiều nhóm và nhiều dịch vụ.



Tổ chức tài khoản và tài nguyên

- Phân tách môi trường: dev, test, staging, production.
- Phân tách theo dự án, đơn vị, mức nhạy cảm hoặc vùng địa lý.
- Áp dụng chính sách quản trị tập trung cho tài khoản con/dự án con.
- Không dùng một tài khoản cloud duy nhất cho mọi hệ thống.

Gắn nhãn tài nguyên

- Tag/label giúp biết tài nguyên thuộc dự án nào, chủ sở hữu nào, môi trường nào.
- Phục vụ phân bổ chi phí, quản trị vòng đời và xử lý sự cố.
- Có thể dùng tag để áp chính sách bảo mật theo môi trường hoặc mức độ dữ liệu.
- Thiếu tag làm môi trường cloud nhanh chóng trở nên khó kiểm soát.

Chính sách dưới dạng mã

- Policy as Code mô tả quy tắc bảo mật và tuân thủ bằng mã có kiểm soát phiên bản.
- Có thể kiểm tra cấu hình trước khi triển khai và phát hiện sai lệch sau triển khai.
- Giúp chuẩn hóa yêu cầu: không public bucket, bắt buộc mã hóa, cấm mở SSH toàn Internet.
- Kết hợp với Infrastructure as Code để kiểm soát hạ tầng từ đầu.

Kiểm toán và tuân thủ

- Tuân thủ yêu cầu về bảo vệ dữ liệu, lưu trữ log, quyền riêng tư và kiểm soát truy cập.
- Cần bằng chứng: log, cấu hình, báo cáo quét, lịch sử thay đổi, phê duyệt và biên bản kiểm thử.
- Kiểm toán cloud cần hiểu cả công nghệ và quy trình quản trị.
- Tuân thủ không đồng nghĩa với an toàn tuyệt đối, nhưng là nền tảng quản trị bắt buộc.

Quản trị rủi ro nhà cung cấp

- Đánh giá SLA, vùng lưu trữ dữ liệu, chứng nhận, hỗ trợ, khả năng xuất dữ liệu.
- Xem xét rủi ro vendor lock-in và kế hoạch thoát/migration.
- Kiểm tra mô hình trách nhiệm, điều khoản bảo mật và khả năng kiểm toán.
- Với dữ liệu nhạy cảm, cần đánh giá yêu cầu pháp lý và vị trí dữ liệu.

Cân bằng bảo mật, chi phí và trải nghiệm

- Bảo mật quá lỏng làm tăng rủi ro; bảo mật quá cứng có thể làm giảm hiệu quả vận hành.
- RTO/RPO thấp, mã hóa nâng cao và giám sát sâu thường làm tăng chi phí.
- Cần xác định hệ thống quan trọng để ưu tiên đầu tư bảo mật phù hợp.
- Quyết định bảo mật nên dựa trên rủi ro, không dựa trên cảm tính.

Tình huống thực hành thiết kế bảo mật

- Thiết kế kiến trúc cloud cho website thương mại điện tử 3 lớp.
- Yêu cầu: public load balancer, private app server, private database, backup, log và IAM.
- Bổ sung: WAF, MFA, mã hóa database, security group, monitoring và DR cơ bản.
- Sinh viên trình bày sơ đồ, giải thích rủi ro và biện pháp kiểm soát.

Bài thực hành Chương 4

- Tạo người dùng/nhóm/role và áp dụng nguyên tắc quyền tối thiểu.
- Bật MFA cho tài khoản quản trị.
- Cấu hình security group chỉ mở cổng cần thiết.
- Bật mã hóa lưu trữ và tạo khóa quản lý.
- Bật nhật ký kiểm toán và thiết lập cảnh báo sự kiện nhạy cảm.
- Kiểm tra lỗi cấu hình bằng checklist bảo mật cloud.

Checklist bảo mật cloud cơ bản

Nhóm kiểm soát	Câu hỏi kiểm tra
IAM	Tài khoản đặc quyền đã bật MFA và phân quyền tối thiểu chưa?
Dữ liệu	Lưu trữ/database đã mã hóa, phân quyền và backup chưa?
Mạng	Có mở cổng quản trị ra Internet hoặc public database không?
Log	Đã bật audit log, flow log và cảnh báo sự kiện nhạy cảm chưa?
DR	Đã xác định RTO/RPO và kiểm thử khôi phục chưa?

Tổng kết Chương 4

- Cloud security bắt đầu từ hiểu đúng mô hình chia sẻ trách nhiệm.
- IAM, mã hóa dữ liệu và phân đoạn mạng là ba nhóm kiểm soát nền tảng.
- Workload security phải bao phủ máy ảo, container, Kubernetes, serverless và API.
- Giám sát, logging, ứng phó sự cố và DR quyết định khả năng phát hiện và phục hồi.
- Governance giúp bảo mật nhất quán ở quy mô tổ chức.

Thank you!

